ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

CyberSecurity

2 - “Overview: Main Concepts and Terminology”

[Chapter 1]

Gabriele D’Angelo <g.dangelo@unibo.it>

https://www.unibo.it/sitoweb/g.dangelo/en

Outline

- Computer Security **Concepts**
- **Threats**, **Attacks**, and **Assets**
- Fundamental Security **Design Principles**
- **Attack Surfaces** and **Attack Trees**
- Computer Security **Strategy**

Fundamental Questions

This slide refers to the central concept and starting point of all computer security and, specifically, describes the fundamental process of threat modeling and risk management.

- The focus is on three **fundamental questions**:

  It helps you identify your assets (that is, everything of value to the organization), whose loss or damage would result in financial or operational harm. If you don't know exactly what you own and how much it's worth, you risk spending money to protect things that aren't important or, worse, leaving your most critical data completely unprotected.

  - **what assets** do we need to **protect**?

  It forces you to conduct a threat analysis by putting yourself in the shoes of a potential attacker: this means understanding who your adversary is, what vulnerabilities your system has, and what types of attacks it might face (e.g., malware, credential theft, DDoS attacks). Understanding threats helps you assess the impact and likelihood of an attack: it allows you to quantify the actual risk.

  - **how** are those assets **threatened**?

  It is used to design countermeasures against an attack. Since 100% security (zero risk) doesn't exist, the goal isn't to eliminate every threat, but to reduce risk to an acceptable level by managing available resources as intelligently as possible. Protecting everything equally would be impossible and incredibly expensive.

  - **what** can we do to **counter those threats**?

Threat Model

You cannot conduct proper risk management without first creating a threat model, and vice versa, a threat model would remain a useless theoretical exercise if risk management did not quantify those risks to determine where to allocate the company's budget.

ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- In cybersecurity, a **threat model** is a **structured** ~~way~~ process of **identifying potential threats**, **vulnerabilities**, and **risks** to a system, application, or organization. It is a **systematic approach** to **understanding the possible attack vectors**, **threat actors**, and the **potential impact** of successful attacks. (definition provided by "claude.ai", 04/03/2024)

Computer Security (NIST definition)

This computer security definition says that it is impossible to have security if we are not able to guarantee the security baseline: CIA Triad (for some system is enough, for others we need to extend the security properties)

Computer security is

- «The protection ~~afforded to~~ provided to an automated information system in order to ~~attain~~ achieve the ~~applicable~~ security objectives established in terms of preserving the **integrity**, **availability** and **confidentiality** of information system resources.»

Protection extends to all the assets of the system

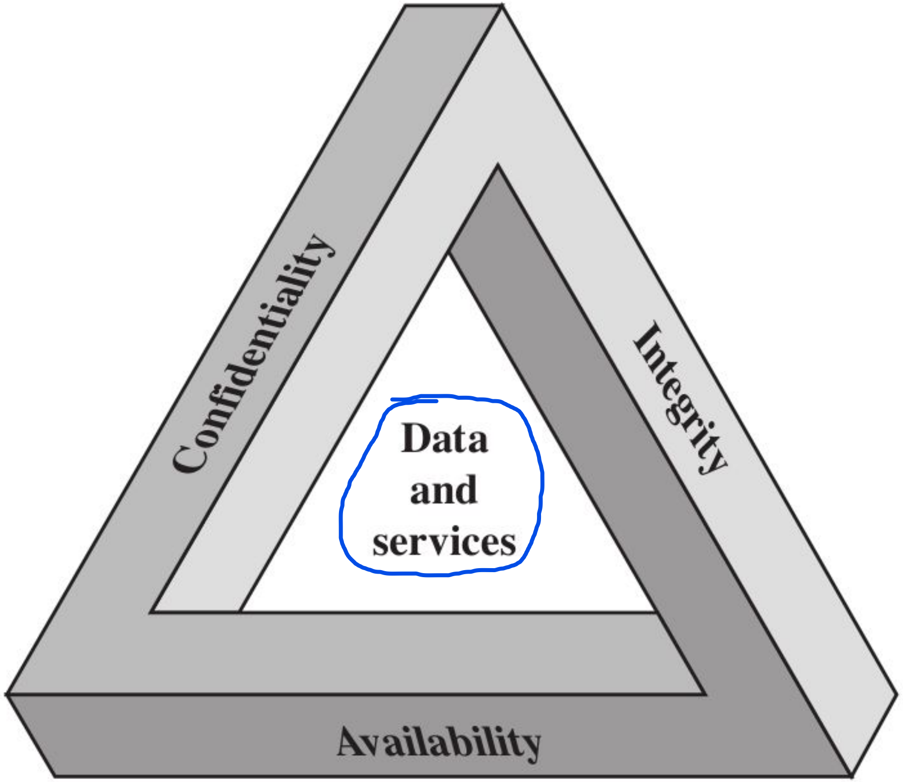
- It includes hardware, software, firmware, information/data, and telecommunications

Professor Methodology: From Awareness to Solutions
- 1. Awareness (Consapevolezza): The "zero-risk" scenario does not exist in cybersecurity. Understanding the current threat landscape, identifying potential Threat Actors, and assessing the strategic value of company assets. Recognition of the need for security as an active, ongoing process.
- 2. Problem Definition: Every system is different (e.g., banking infrastructures require different properties than medical IoT devices). To define the problem, you must explicitly define the security properties that need to be guaranteed. Executing custom Threat Modeling and Risk Assessment based on the specific architecture.
- 3. Solutions must never be generic; they are engineered exclusively to solve the problem defined in the previous step. Implementing a multi-layered mitigation strategy

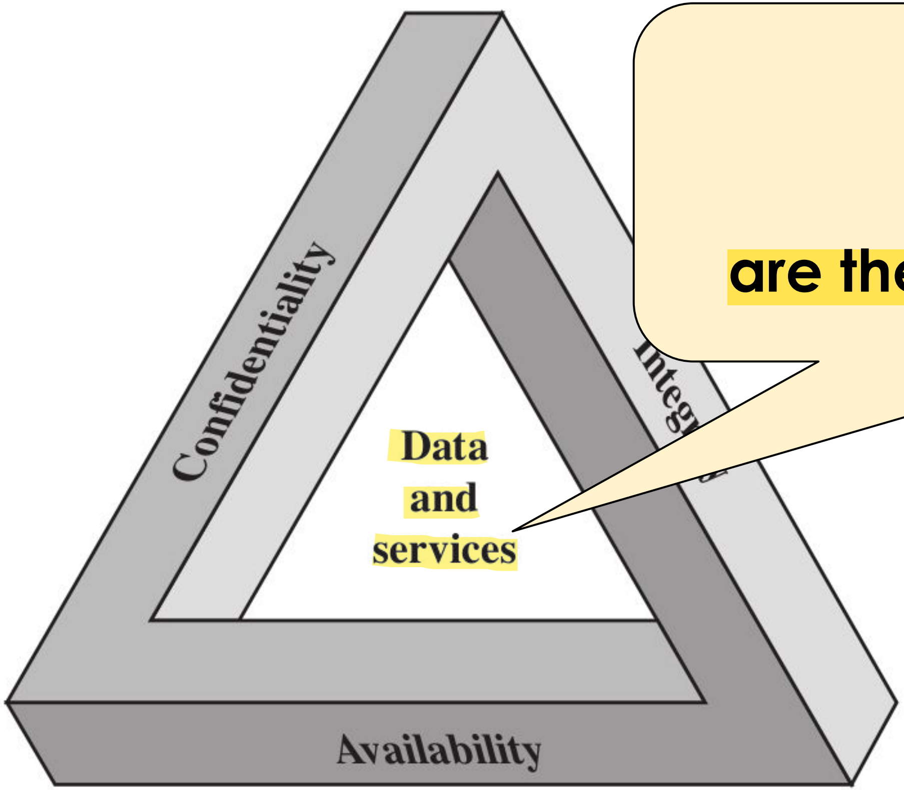
The Security Requirements "CIA" Triad

ALMA MATER STUDIORUM UNIVERSITÀ DI BOLOGNA

They are referred to as " Requirements" because they establish the mandatory objectives that must be met in order for a system to be officially defined as "secure": cybersecurity consists precisely of the protection provided to a system in order to preserve these three specific properties of the organization's assets.



The Security Requirements "CIA" Triad

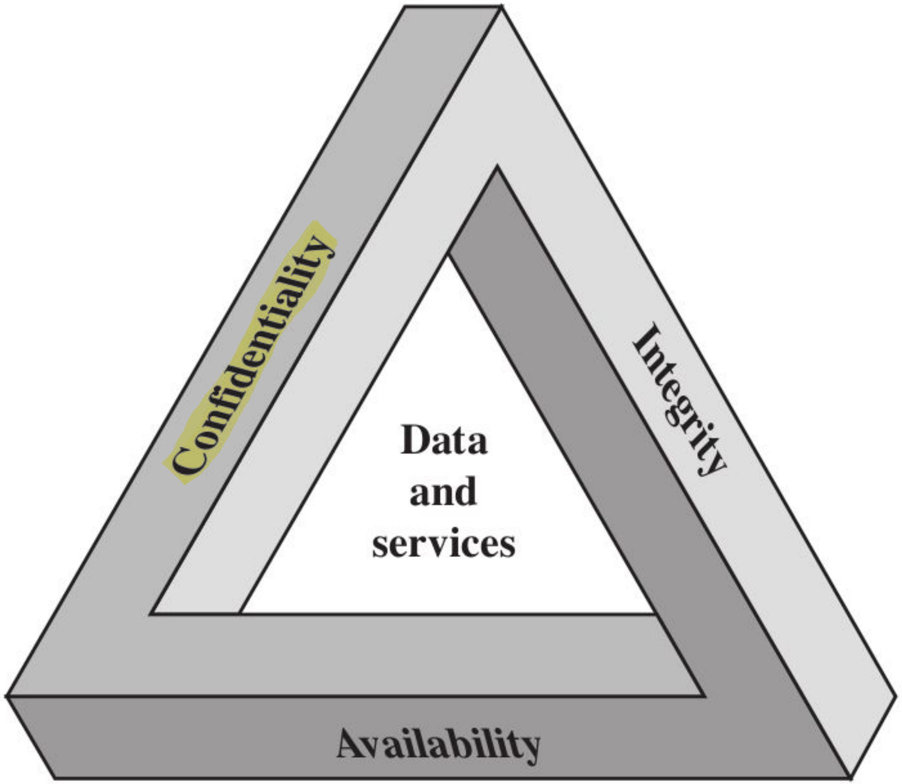


In this approach

"data and services"

are the core elements to protect

The Security Requirements "CIA" Triad

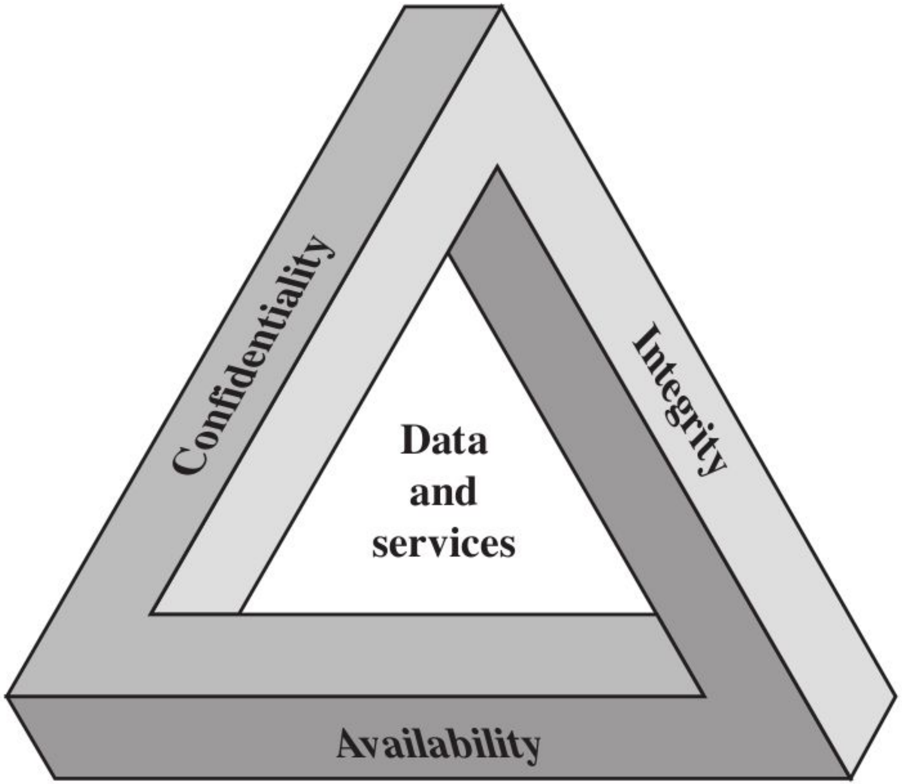


confidentiality divided in two different things:

→ **data confidentiality**

→ **privacy** (small subset of Cybersecurity)

The Security Requirements "CIA" Triad



confidentiality

→ data confidentiality

→ privacy

example: logs of my activity on Unibo WiFi must be private

data confidentiality

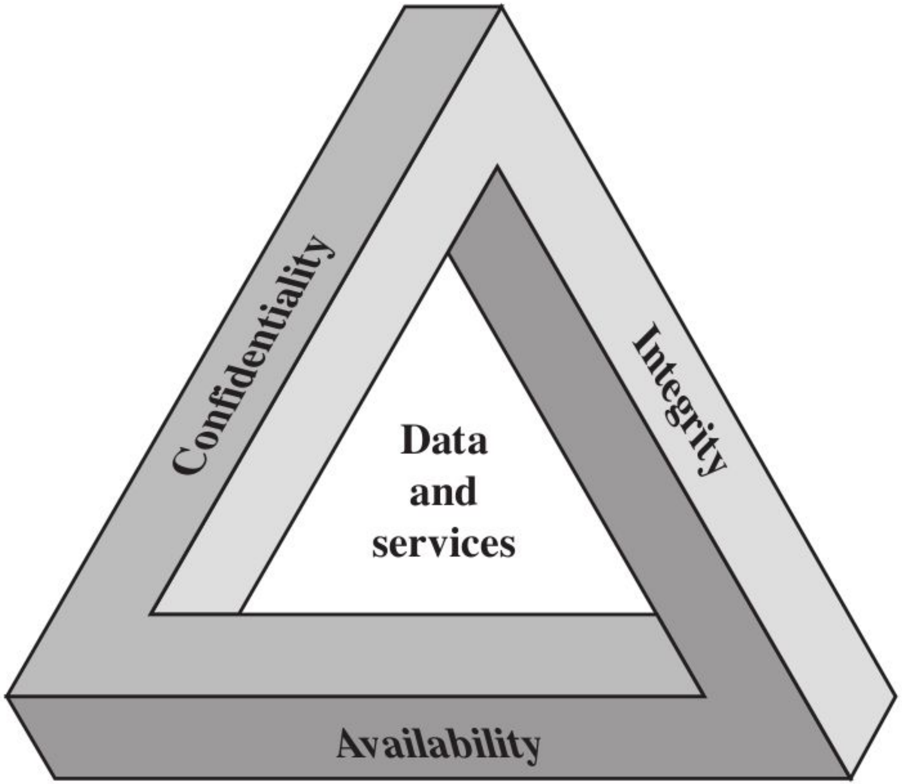
private or confidential

information is not made

available or disclosed

to unauthorized individuals

The Security Requirements “CIA” Triad



confidentiality

→ **data confidentiality**

→ **privacy**

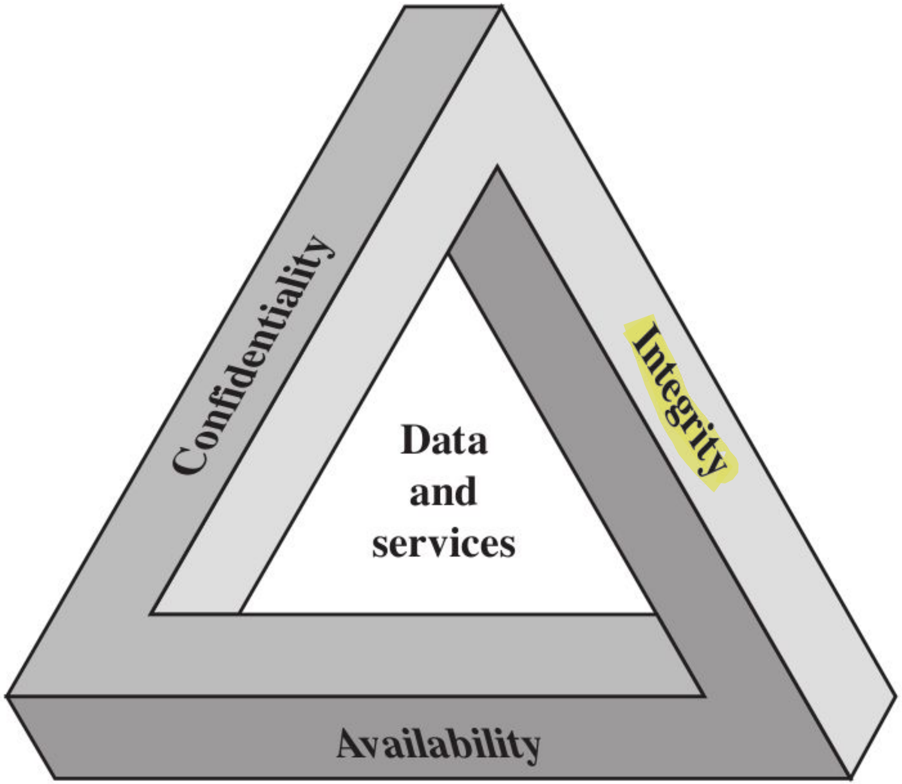
example: I can control the level of visibility of my pictures on Instagram

privacy

For some data can be done, for other is difficult to be done or not be done

individuals control [1] what information related to them may be collected and stored, [2] by whom and [3] to whom this information may be disclosed

The Security Requirements "CIA" Triad

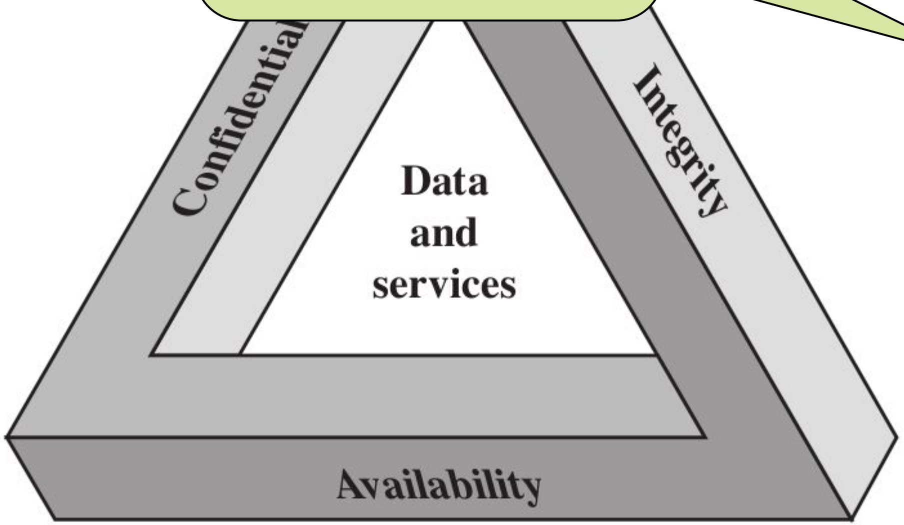


confidentiality
- → data confidentiality
- → privacy

integrity
- → data integrity
- → system integrity

The Security Requirements "CIA" Triad

data
AND
programs



confidentiality

→ data confidentiality

→ privacy

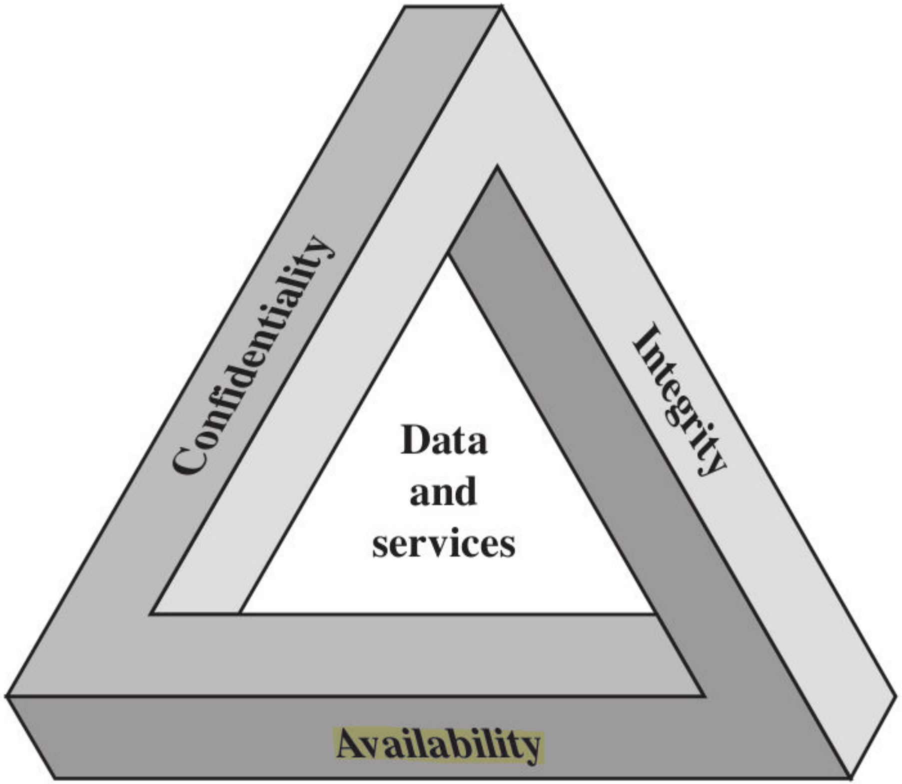
integrity

No unauthorized modification are done

→ data integrity

→ system integrity

The Security Requirements “CIA” Triad



confidentiality
- → data confidentiality
- → privacy

integrity
- → data integrity
- → system integrity

availability
- → data availability
- → services availability

Key Security Concepts

Confidentiality → Integrity → Availability

Any security strategy aims to protect these security properties/requirements as they apply to system data and services.

Key Security Concepts

Confidentiality | Integrity | Availability

- Preserving authorized restrictions on **information access** and **disclosure**
- Including ~~means~~ measures for protecting personal **privacy** and proprietary information

Key Security Concepts

Confidentiality | Integrity | Availability

- Guarding against ~~improper~~ unauthorized **information modification** or **destruction** (example: ransomware to attack the integrity of a system)
- Including ensuring information **non-repudiation** and **authenticity**

(Non-repudiation is the legal and technical assurance that a particular person cannot deny having performed a specific action.)

(Authenticity is the guarantee that a message, transaction, or data actually comes from the source it claims to be from.)

Key Security Concepts

Confidentiality

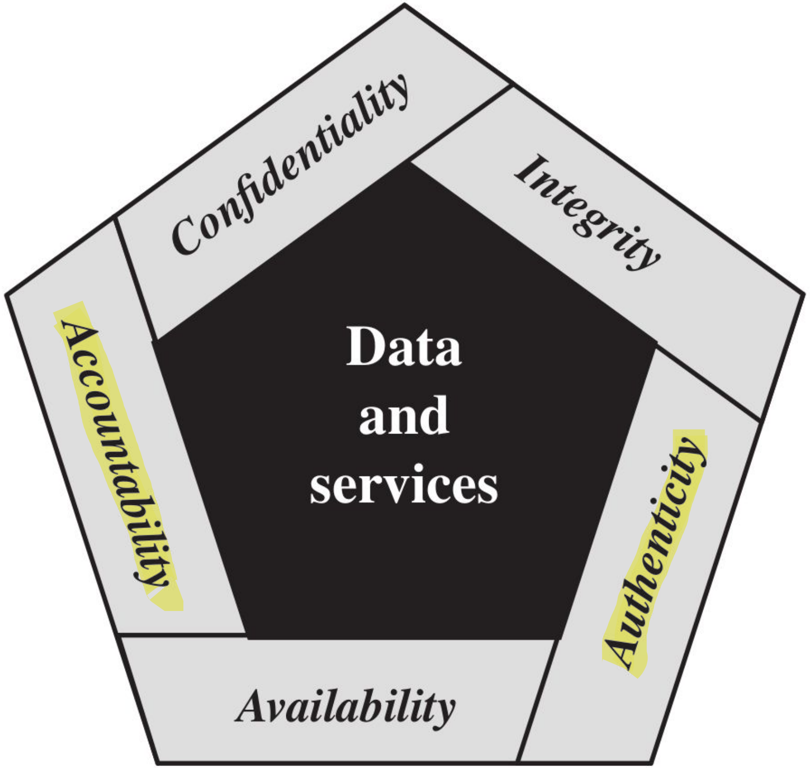
Integrity

Availability

- Ensuring **timely** and **reliable access** to ~~and use of~~ **data** (and **services**)

The Security Requirements

The CIA Triad and its extension, the Pentagon of Security, are used as conceptual models and reference frameworks for defining the fundamental security objectives of any cybersecurity strategy.



Every single system has different security requirements: in some cases Triad is enough, in other cases the Triad isn't enough and the Pentagon is enough, in other cases Pentagon isn't enough and we need something else.

Complexity of the system is higher in Pentagon Requirements, than in Triad

Key Security Concepts

- Authenticity
- Accountability

Key Security Concepts

ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Authenticity

This means that an entity is exactly what it claims to be.

- Property of being **genuine** and being able to be **verified** and **trusted**

The system must possess technical or mathematical mechanisms to objectively prove that identity.

If an entity is genuine and successfully passes the verification process, the system can finally grant it access.

- **For example**: *confidence in the validity of a **transmission**, a **message**, or a message **originator***

Accountability

Key Security Concepts

Authenticity

Accountability

Achieving absolute Accountability is an exceptionally difficult task in cybersecurity, and its feasibility heavily relies on the specific environment (e.g., an internal corporate network versus the public Internet).
- Within Organizations: Guaranteeing accountability is highly achievable because the infrastructure is centralized and tightly managed. Every action can be traced uniquely to a single user through unmodifiable activity logs. However, this level of control comes at a direct cost, as it significantly reduces user privacy.
- On the Internet: Ensuring accountability is fundamentally constrained by the very nature of the web. Because the Internet is decentralized, spans across conflicting legal jurisdictions, and natively supports layers of anonymity, finding the true originator of a malicious transmission is incredibly hard.

In the end, accountability and privacy are linked in a trade-off: to increase accountability, a system must require total transparency, which in itself sacrifices individual anonymity and erodes privacy.

- The requirement for **actions of an entity** to be **traced uniquely to that entity**
- **For example**: *ability to find the originator of a **transmission**, a **message**, or an action*

Key Security Concepts

If a company suffers financial loss or a serious breach, it may want to pursue legal action against those responsible (whether they are external hackers or disloyal employees). To go to court, you need evidence. If system logs have been collected and stored securely, in an unmodifiable manner, and in compliance with regulations, they serve as digital forensic evidence, allowing lawyers to take legal action backed by objective facts.

Without Accountability is not possible to trace in which part of the system the fault has originated

Authenticity

if a malicious employee or system administrator knows that the infrastructure logs every single action they take, they will be strongly discouraged from engaging in illegal activities. They know they would be caught immediately.

Accountability

I need Accountability

~~Necessary~~ **to support non-repudiation, deterrence, fault isolation, intrusion detection** and **prevention... recovery** and **legal action**

The requirement for **actions of an entity** to be **traced uniquely to that entity**

I monitor the system, I check what happens. If something that is anomalous is happening on the system, i stop immediately what happens

- **For example**: *ability to find the originator of a* ***transmission****, a* ***message****, or an action*

If things go wrong, you need to be able to decide what has been compromised and what not, and restore the things that has been compromised and maintain everything that has not been compromised

Important to have in case of Failure of system protection (System compromised in real world, it happens). We can do Intrusion Detection and Prevention if we have Accountability

Qualitative classification of Impact

Level of Impact

ALMA MATER STUDIORUM UNIVERSITÀ DI BOLOGNA

A security breach of a system, caused by a successful attack, can have 3 different levels of impact:

1

Low

of a specific security property

The loss could be expected to have a **limited** negative ~~**adverse**~~ **effect** on organizational **operations**, organizational **assets**, or **individuals**

2

Moderate

The loss could be expected to have a **serious** negative ~~**adverse**~~ **effect** on organizational **operations**, organizational **assets**, or **individuals**

3

High

The loss could be expected to have a **severe or catastrophic** negative ~~**adverse**~~ **effect** on organizational **operations**, organizational **assets**, or **individuals**

Computer Security Challenges

ALMA MATER STUDIORUM UNIVERSITÀ DI BOLOGNA

1 • Computer security is **not as simple as it might first appear to the novice**

You need to design your defenses with the understanding that they will be the attacker's target.

2 • **Potential attacks** on the system security features must be considered

(Example: HTTPS on the internet. The original goal of the internet was maximum efficiency, speed, and ease of connection. Security completely changes this initial goal, on which the internet's design was based, by introducing various steps that might seem like pure madness and a waste of resources.)

3 • Procedures, used to provide particular security services, are **often counterintuitive**

The procedures used to ensure security in legacy systems are often counterintuitive, as they require adapting security measures to technologies designed before modern threats existed. As systems evolve over time, understanding how different components enable specific functionalities makes it difficult to ensure their security, often leading to the need for "corrective controls" rather than fundamental solutions.

4 • **Physical** and **logical placement** of security mechanisms needs to be determined

because it establishes security boundaries and determines the overall effectiveness of both physical and digital controls. If the exact location where a computation is performed remains unknown, verifying the system's integrity becomes impossible.

5 • **Multiple** security **algorithms** or **protocols** may be involved

While combining techniques can sometimes strengthen security, it often results in increased complexity, potential vulnerabilities at interface points, and increased maintenance overhead.

Computer Security Challenges
when you want to protect your system

6

- **Attackers** only need to find a **single weakness** /vulnerability in the system
- **Developers/administrators** need to find **all weaknesses** and try to fix them all (or mitigate the risk posed by the fact that they remain unresolved)
- It is an **asymmetric game**! (*i.e. the players do not stand on equal ground*) the knowledge of the system is important, so do not disclose so much information
- The attacker can **combine multiple weaknesses** (in the real world, start with non-tech vulnerability, humanware, then chain of tech vulnerability)

Computer Security Challenges

7 - **Users** and **system managers** tend to **not see the benefits** of security **until a failure occurs**

(good security can effect usability: if the security is invisible, it doesn't impact the work of the users)

  - **good security** is **invisible**
  - **bad security** is **visible only after a security incident**
  - (usually) **good security does not generate revenues** (*i.e. if compared with advertisements, marketing etc.*)

Computer Security Challenges

8 • Security requires **regular and constant monitoring** (*i.e. security is a* ***process** and not a **product***)… **security is costly**!

Every single day, you will have to invest money and maintaining a proper security level

Computer security

9 • It's often an **afterthought** to be incorporated into a system **after the design is complete** (*i.e. the Internet*)

and not meanwhile

(If you attempt to implement security only after completing a system's design, you will meet structural problems that cannot be solved. It is technically impossible to ensure an appropriate level of protection on an existing architecture, since security cannot be a later addition; rather, it must be natively integrated from the earliest stages of design)

use protocol, to enhance security, on top of internet low protocols (after its design)

(Example: Two-level Authentication, too much time to login in an account than using only password, but you have more security)

10 • **Thought of as** an **impediment** to **efficient** and **user-friendly operation**… (again) **security is a cost**!

A common challenge for cybersecurity specialists is asking the CEO for additional funding to enhance system security

Computer Security Terminology

The attacker tries to minimize the cost of the attack in every possible way, so the first phase of the attack is often automated (after the initial phases, a human user steps in)

1

- **Adversary** (**threat agent**): an **entity that attacks**, or **is a threat** to, a system

(It isn't only about an attack that is implemented, it can be also about potential attack). We need to anticipate what will happen: so we will need to consider all the entities that can be interested in attacking our system.

An attacker is an entity that wants to violate an organization's security policy. Consequently, if the policy does not define or take into consideration certain critical resources or behaviors, any resulting compromise cannot be formally classified or reported as a security breach, since technically no established rule has been violated.

2

- **Attack**: an assault on system security that ~~derives~~ comes from an **intelligent threat**; a deliberate attempt **to ~~evade~~ bypass security services** and **violate** the **security policy of a system**

an action intended to compromise the security of a system

(Example: Evade the Auth Mechanism)

(Example: can you play on Uni PCs during launch? It is defined in the security policy of the system)

Computer Security Terminology

- **Adversary** (**threat agent**): an **entity t** ... **reat** to, a system
- **Attack**: an assault on system security that derives from an **intelligent threat**; a deliberate attempt **to evade security services** and **violate** the **security policy of a system**

In some cases the threat is not much "intelligent"

Example: *some (not all) Denial of Service attacks are rather* ***simple*** *(or stupid)*

Example: Volumetric DoS: throw a lot of packets to the system to attack

... or **is a threat** to, a

- **Attack**: an assault on system security that derives from an **intelligent threat**; a deliberate attempt **to evade security services** and **violate** the **security policy of a system**

Computer Security Terminology

ALMA MATER STUDIORUM UNIVERSITÀ DI BOLOGNA

3

In cybersecurity, completely eliminating a threat or vulnerability is often impossible due to technical, operational, or financial constraints. Therefore, countermeasures must focus on mitigating risk by reducing the attack surface and minimizing the potential harm caused by an exploit.

Countermeasure: an **action**, **device**, **procedure**, or **technique** that **reduces a threat, a vulnerability, or an attack** by (1 prevention) **eliminating** or **preventing** it, (2 detect and recovery) by **minimizing** the **harm it can cause**, or (3) by discovering and reporting it (the vulnerability) so that **corrective actions can be taken**

Discover and Report the Vulnerability is a countermeasure (Discover and selling it to Vulnerability Broker isn't a countermeasure)

What happens if the attacker is able to exploit part of my Attack surface to compromise a specific service that is open to the external of my organisation? How much time for come back operational? This must be done every day for every risk that involves my organisation (this must be done for proper evaluating the assets that are inside my system)

Computer Security Terminology

ALMA MATER STUDIORUM UNIVERSITÀ DI BOLOGNA

- System: HW and SW used to provide some stuff/services of the business (can be a bunch of interconnected systems).
- Organisation: something related to Management of company and pays you money

4 • **Risk**: an **expectation of loss** expressed as the **probability** that a **particular threat** will exploit a **particular vulnerability** with a **particular harmful result** (damaging)

For every single threat to your system, you must be able to properly classify this threat assigning a specific level of risk (cell of the risk matrix).

Example: phishing email to download from outside the organisation a ramsonware (likelihood: almost certain; impact: it encrypts all data and backups and the attacker asks money; you are with a critical risk). Based on the risk, you have to find a countermeasure to reduce the impact, so it reduces the risk (example: education of the employee, in this case)

This table is the follow-up of the Classification of Level of Impact

When we are in charge of the security of a System, our job is minimizing the risk by means of whatever you want (i.e specific countermeasures)

Impact	Likelihood: Rare	Unlikely	Possible	Likely	Almost certain
Catastrophic	moderate	moderate	high	critical	critical
Major	low	moderate	moderate	high	critical
Moderate	low	moderate	moderate	moderate	high
Minor	very low	low	moderate	moderate	moderate
Insignificant	very low	very low	low	low	moderate

So, you can reduce impact and likelihood with tech and human solutions (example: filtering to reduce likelihood of download malware and education to reduce impact)

RISK MATRIX

In some cases, very likely, you are going to use a combination of different countermeasures.

Computer Security Terminology

From a technical POV, a well-defined security policy is indispensable: it establishes the precise boundaries of what can be actively defended. Without clear scope and authorization from the policy, protecting disparate parts of an organization becomes an impossible task. Paradoxically, modern security policies are often shaped not by technical necessity, but by external and non-technical pressures, such as compliance frameworks, legal regulations, and the rigid requirements of third-party certifications.

5

Security policy: a **set of rules and** procedures ~~**practices**~~ that specify **how a system or organization provides security services** (with the aim *to protect sensitive and critical system resources*)

The effectiveness of a security policy depends entirely on the organization's ability to enforce it. A critical and recurring issue arises when security professionals lack the necessary authority or support from senior management to enforce these rules with respect to executives or their own superiors. Furthermore, the strict enforcement of a security policy often creates friction, making the security team very unpopular within the organization. This resistance creates a twofold challenge:
- Technical obstacles: dealing with vulnerabilities, managing restrictive access controls, and maintaining strict password policies.
- Interpersonal friction: dealing with human resistance, navigating corporate culture, and balancing operational usability with security constraints.

Example: *the **password policy** (i.e. strong passwords and their expiration) of an organization is part of its **security policy***

Computer Security Terminology

6 • **System resource** (**asset**): **data**; a **service** provided by a system; a **system capability**; an **item** of **system equipment**; a building (where the computation is placed) ~~**facility**~~ that houses system operations and equipment

If i have a vulnerable device, it is important to not expose it on the internet (i can define rules in the Firewall/Router to avoid the communication with it from the outside)

7 • **Threat**: a **potential** ~~for~~ **violation of security**, that occurs ~~which exists~~ when there is a situation ~~circumstance, capability~~, action, or event that could compromise the ~~**breach**~~ **security** of the system and **cause harm** (it is important to define level of impact and likelihood (so, the risk) involved with these potential threats)

Computer Security Terminology

8

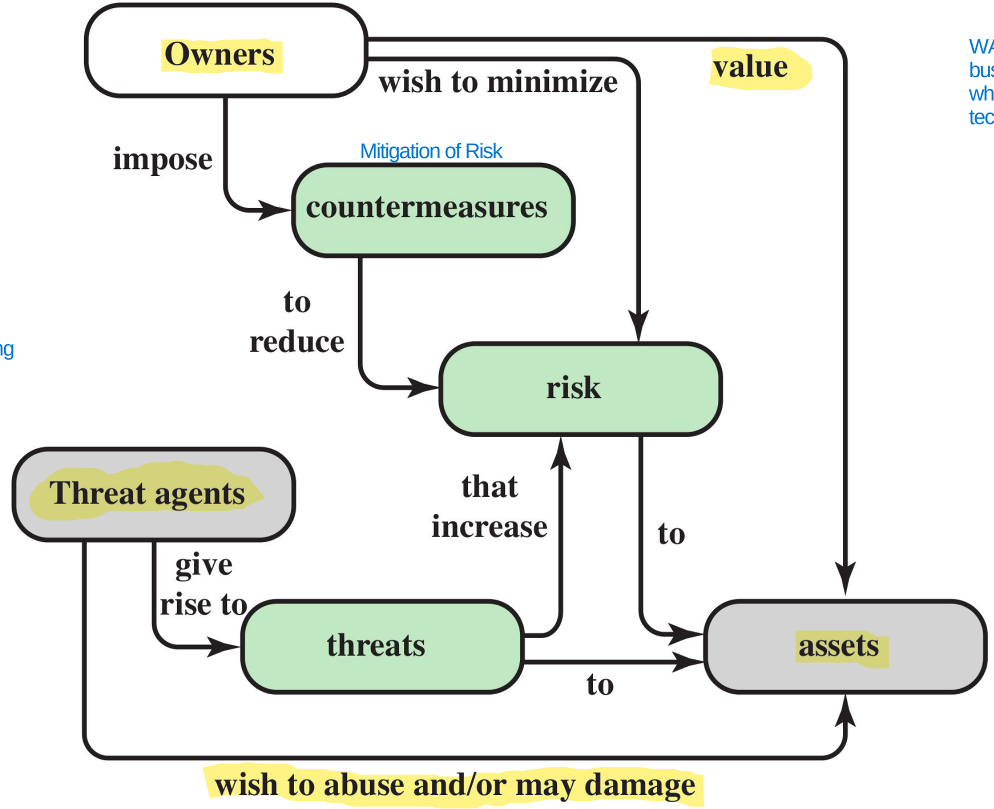
- **Vulnerability**: a **flaw** or **weakness** in a system's **design**, **implementation**, or **operation** and **management** that could be **exploited** to **violate the system's security policy**

(if it isn't in the Security policy, it isn't a vulnerability (outside of the scope of the system): in some cases, it is an error/flaw in the policy or in the system implemented)

Example: *there is a vulnerability in the* ***software*** *or the* ***users*** *are* ***not properly educated*** *to deal with email phishing*

Security Concepts and Relationship

It seems easy to manage the risk of all assets (Asset Risk Management), but in practice to list all the threats and then being able to decide the proper countermeasures can be costly and boring



WARNING: The diagram provides a " business-level" overview (who owns what and who wants to cause harm), but it lacks the " technical" details (how the harm occurs) and

In the middle between Business and Threat Agent, there are Assets (core of the business for providing services)

Vulnerabilities, Threats and Attacks

ALMA MATER STUDIORUM UNIVERSITÀ DI BOLOGNA

A system resource is considered vulnerable if it can suffer one of these three outcomes as a result of an attack

- **Vulnerability** (of system resources):

system resource is

when there is a

  - **corrupted** (loss of **integrity**)

Example: An attacker breaks into a bank's db and doesn't steal money, but changes your account balance from €100 to €1,000,000. The system is “corrupted.”

system resource is

when there is a

  - **leaky** (loss of **confidentiality**)

Example: A vulnerability in a website allows an unauthorized person to access patients' medical records. The data has not been lost or altered, but it has been “leaked.”

system resource is

when there is a

  - **unavailable** or very slow / **unresponsive** (loss of **availability**)

Example: A DDoS attack that floods a server with fake requests until it crashes. Or, ransomware that encrypts your files: the data is still there (its integrity and confidentiality may be intact), but you cannot use it.

Vulnerabilities, Threats and Attacks

Formalization of Threat

- **Threats**:

  If there is a vulnerability in your code, the threat comes from an attacker who knows how to write exploit code to take advantage of that specific flaw. If there were no vulnerabilities in the system, the threat would remain outside the door, unable to act. The threat needs the vulnerability to turn into an actual attack.

  - capable of **exploiting vulnerabilities**

  This represents the possibility that the CIA Triad could be compromised, causing economic, reputational, or operational harm to the organization.

  - represent a **potential security harm**

Vulnerabilities, Threats and Attacks

ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

(three categories)

is no more potential: is something that is happening

- **Attacks** (threats carried out):

What matters is not the classification itself, but the consequences of the classification:
- active: i can monitor what happens and react and try to mitigate (example: attacker trying to stole an account trying different passwords, the system can, one solution, block the account avoiding login)
- passive: monitoring isn't useful, so i need to work on countermeasure (very hard to implement) (example: attacker snif the connection and grab the wifi password encrypted without interacting with system)

  - **active** - attempt to ~~**alter**~~ modify/**affect** the **system resources** or to affect their operation. (direct interaction with system)
  - **passive** – does **not** (directly) **affect** the **system resources** (no direct interaction with the system itself: like intercept comunication)
  - **insider** or **outsider** (is it from an **internal** or **external** ~~**thread**~~ threat?)

In the past, everything that is outside is bad and everything that is inside is good (example: LAN protocol is designed based on this). Now, the world changed a lot and most of attacks comes from inside, for example by compromission of device/applications. Now, it is used a lot the Zero-Trust Approach (everything is untrusted up to when you demonstrate that you are legitimated to do something: every time that there is an interaction with the infrastructure, you must be able to validate yourself and to demonstrate that you are legitimated)

Vulnerabiliti

Più avanti si parlerà di più di questo

More info about active and passive attacks in the following...

- **Attacks** (threa
  - **active** - at mpt to **alter/affect** the **system resources**
  - **passive** – does **not** (directly) **affect** the **system resources**
  - **insider** or **outsider** (is it from an **internal** or **external thread**?)

Countermeasures

ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

All three are very important

- **Any ~~means~~** measures taken **to deal with a security attack**

  - try my best to **prevent** the attack
  - **detect** the attack until it is to late
  - If the system is compromised, i need to **recover** from attack

Define the steps for each, before being compromised

Countermeasures

ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Any means** taken **to deal with a security attack**
  - **prevent**
  - **detect**
  - **recove**

Is that always possible?

Countermeasures

ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Any means** taken **to deal with a security attack**
  - **prevent**
  - **detect**
  - **recove**

(Example: Vulnerability in the Web Server and i don't have the update to fix it (can't prevent). So, because i can't shutdown the entire Web Server and i can't do nothing to prevent the compromission, i do my best for enhancing the detection of compromission and recovery if it happens)

No! That's why detection and recovery are of main importance

Countermeasures

- **Any means** taken **to deal with a security attack**
  - **prevent**
  - **detect**
  - **recover**

Countermeasures

Countermeasures

- May **introduce new vulnerabilities**

- **Residual vulnerabilities** may **remain**

Such vulnerabilities may be exploited by threat agents representing a residual level of risk to the assets.

- The **goal** is to **minimize residual level of risk** to the assets

(*that is to implement some kind of **mitigation***)

Tipically, you have similar type of attack of different systems (so classify them is important to deny the attack to this category). Although the CIA triad was originally developed to define security objectives, in practice it is frequently used to classify threats based on which pillar they target.

If an attack is successful, it leads to an undesirable violation of security (Threat Consequences of the attack)

Threat Consequences

Threats are linked to CIA Triad through vulnerabilities

ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

4 Different classification that is useful to understand the different typical attacks

A

Divulgazione non autorizzata

- **Unauthorized disclosure** is a threat to **confidentiality**

There are various types of attacks that lead to the same end result: someone sees something they shouldn't.

Exposure: the accidental or intentional disclosure of sensitive data in an unsecured environment.

intentional

1 ○ **exposure**: *this can be **deliberate** or be the result of a human, hardware, or software **error***

Example: An employee accidentally posts an Excel file containing salary information on the company's public website, or a database server is left unsecured on the internet.

Interception: occurs when data is captured as it travels from point A to point B (more related to communication in a network)

2 ○ **interception**: *unauthorized **access** to data*

Example: The classic man-in-the-middle (MitM) attack. You connect to the airport's Wi-Fi, and an attacker intercepts the data packets you send to your bank.

Inference: secret information is obtained by analyzing data that is not secret or by observing the system's behavior.

3 ○ **inference**: *e.g., traffic **analysis** or use of limited access to get detailed information*

Example: I can't read the contents of your emails (they're encrypted), but I see that every morning at 9:00 a.m. you send an email to the legal department and then to the CEO. I can infer that there's a legal negotiation underway.

Intrusion: direct, unauthorized access to a system for the purpose of stealing data (example: get data from db).

4 ○ **intrusion**: *unauthorized **access** to sensitive data*

Example: A hacker exploits a vulnerability in the web server to gain a "shell" (control of the computer) and manually copies sensitive files to their PC.

Threat Consequences

ALMA MATER STUDIORUM UNIVERSITÀ DI BOLOGNA

3 Different classification that is useful to understand the different typical attacks

B

Inganno

- **Deception** is a threat to either **system** or **data integrity**

1 It's an attack on identity. The system thinks it's talking to Mario Rossi, but it's actually talking to Fabio Verdi.

Example: Trojan malware impersonating good software with backdoors or other things. Another example: modify IP address on a packet to avoid filters on addresses and push malware

- ***masquerade***: *e.g., Trojan horse; or an attempt by an unauthorized user to gain **access** to a system **by posing as** an authorized user*

(example: DNS poisoning corrupts the records in a DNS resolver's cache, redirecting users from legitimate websites to fake or malicious sites)

2 This is a direct attack on the data. In this case, the attacker already has access (or gains it) and alters the existing information.

the internet is insecure and the travel of data on the internet is less secure than in the system

- **falsification**: *the **alteration** or **replacement** of valid data or the **introduction** of false data*

Example: I enter new fake records (e.g., I create a fictitious "admin" user so I can log in later).

3 It occurs when someone performs an action and then lies by claiming they didn't do it, or when the system is unable to prove that it was done.

tricks

- **repudiation**: *an entity **deceives** another by falsely **denying** **responsibility** for an act*

Example: I make an online purchase, receive the merchandise, but then tell the bank, "I never authorized that transaction; give me my money back."

Threat Consequences

ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

3 Different classification that is useful to understand the different typical attacks

Interruzione

C **Disruption** is a threat to **availability** or system **integrity**

1 The system simply stops existing or functioning because the physical foundation is destroyed (Attack to Availability)

- **incapacitation**: *a result of physical **destruction** of or **damage** to system hardware*

Example: A malicious actor cuts the fiber optic cables leading to a data center.

2 The system is still up, but it's doing the wrong thing or behaving chaotically (Attack to system integrity)

- **corruption**: *system resources or services function in an **unintended** manner; **unauthorized** modification*

Example: An attacker modifies the routing table of a router. The router is on, but it's sending all your traffic to a dead end or a malicious server.

3 The system is working correctly and the data is fine, but the path to get there is blocked or so slow that it becomes useless (Attack to Availability)

- **obstruction**: e.g. **overload** the system or interfere with communications

Example: A DDoS (Distributed Denial of Service) attack. The server is fine, the data is safe, but 1 million fake users are knocking on the door, so the authorized users can't get in.

It isn't important to classify PRECISELY every incident. When i want to know if a system is secure or not, I need a procedure to be followed: use these 4 slides as Guidelines to assess the security of the system

The main criticism of this model (last 4 pages) is that the categories often bleed into one another. Because one attack can hit all four categories, it can feel like the classification isn't "sharp" enough to define a specific event.

Threat Consequences

2 Different classification that is useful to understand the different typical attacks

D

Usurpazione

- **Usurpation** is a threat to **system integrity**

Misappropriation is defined as the unauthorised acquisition of control or privileges of a resource (the attacker takes possession of the resource itself), while misuse occurs when the attacker, even without having stolen ownership of the resource, manages to manipulate its behavior to force it to perform functions that are harmful to the system's security.

This is a threat to the ownership and access of a resource.

1 ○ **misappropriation**: *an entity ~~assumes~~ gains **unauthorized** logical or physical **control** of a system resource*

Example: An attacker gains Root access to your web server. They haven't broken it (yet), but now they own all the data and processing power on it.

Without being detected, by using a system in a way other than its intended purpose

2 ○ **misuse**: *causes a system component to perform a function or service that ~~is~~ ~~detrimental to~~ is harmful to **system security***

- Example: Using a legitimate company email server to send out millions of Spam messages or Phishing links. The server is doing what it was built for (sending emails), but it is being misused in a way that damages the company's reputation and security.
- Another Example: An attacker installs a Crypto-miner on your server. The server still hosts your website, but it's wasting 90% of its CPU power making money for the hacker.

Cybersecurity is composed of several macro-areas (Network Security, Software/File Security, Physical/Access Security). When assessing the security of a system, you must consider them all together. A chain is only as strong as its weakest link.

Scope of Computer Security

(Example of Attack: Man-in-the-middle, somebody intercepting communication, modifying packets and impersonating the destination of

(Internet is insecure: it is used Encryption to communicate between two system)

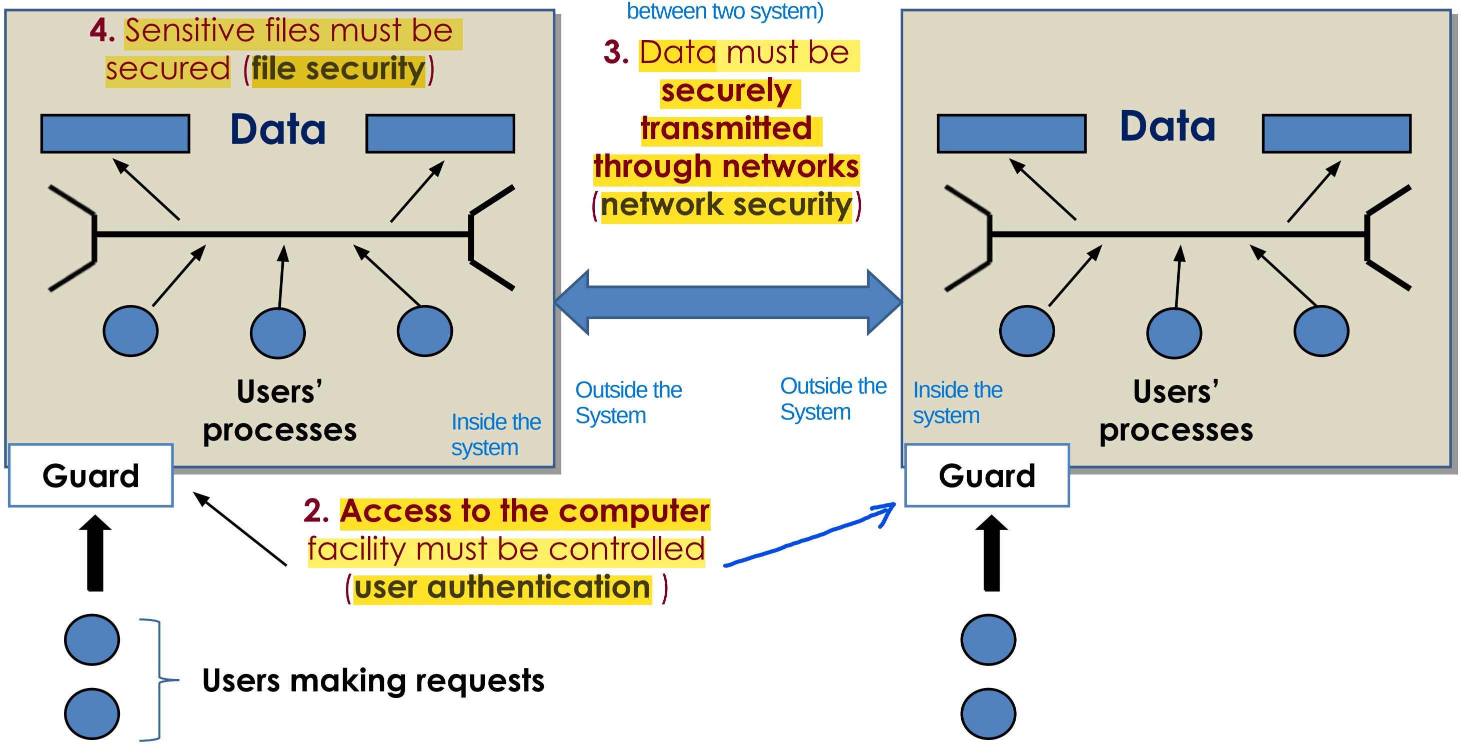
Computer System

Computer System

4. Sensitive files must be secured (**file security**)

3. Data must be **securely transmitted through networks** (**network security**)

1. **Access to the data** must be controlled (**protection**)



2. **Access to the computer** facility must be controlled (**user authentication**)

This table is good to be used as Guideline to analyse the system security in terms of CIA Triad or design properly a system. If a mechanism (part of system) can't properly react/resist to these kind of actions by the attacker (example: Data Integrity Issues), it means that you are using a System that is prone to this kind of actions

The cells contain examples of threats to a specific security property that needs to be ensured for a certain type of asset

A critical challenge in maintaining Data Confidentiality and Integrity is detection: how do you know when an unauthorized read, modification, or creation has occurred? Addressing this requires a robust security infrastructure capable of continuously tracking data leaks, unauthorized alterations, and malicious data injections. Furthermore, organizations must maintain precise security incident reporting procedures. When a breach occurs, they must legally and transparently report exactly what data was compromised—or potentially exposed—as attempts to conceal a breach can result in severe regulatory fines and legal liabilities.

Scope of Computer Security

Digital Forencis: It is the practice of identifying, preserving, extracting, and documenting computer evidence so that it can be used in a court of law or an internal investigation.

CIA Triad

Assets of a Computer System	**Availability**	**Confidentiality**	**Integrity**
Hardware	Equipment is stolen or disabled, thus denying service	An unencrypted USB drive is stolen	Author of the book thinks that rarely the integrity of the hardware can be affected (not true, example of skimmers in ATMs)
Software	Programs are deleted, denying access to users	It is Software Piracy An unauthorized copy of software is made	A working program is modified to cause it to fail or to cause it to do some unintended task
Data	(Example of attack: Ramsonware) Files are deleted, denying access to users	An unauthorized read of data is performed. An analysis of statistical data reveals underlying data (User Auth and Authorization (Access Control) is important)	User Auth and Control Access is important (if the file can be modified only by his author, we don't have unauthorized modifications) Existing files are modified or new files are fabricated Given that we aren't able to verify a property, we try to avoid the problem by means of a constraint in the definition of the problem itself (Instead of constantly checking if a file is "correct," you limit who can touch it so that it cannot be incorrect: this is shifting from Detection (checking for errors) to Prevention by Design (using constraints to make errors impossible).)
Communication Lines and Networks	(Internet is not designed for Availability) Messages are destroyed or deleted. Communication lines or networks are rendered unavailable	example: same comunication with server for paying will be duplicated to do the same other times Messages are read. Traffic patterns are observed reordered: if a protocol doesn't have a Sequence Number, an attacker can modify the order of the messages	Messages are modified, delayed, reordered, duplicated. False messages are fabricated All actions that an entity between source and destination can do with a Packet if the channel isn't secure (ex: HTTP)

If you simply say, "I have a loss of confidentiality", you've only identified the general problem. The specific details about the assets are what help you understand exactly what has been compromised, because they completely change depending on the context: The vulnerability the attacker exploited. The actual damage to the company. The technical countermeasure you need to implement to resolve the issue.

Scope of Computer Security

ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

	Availability	Confidentiality	Integrity
Hardware	Equipment is stolen or disabled, thus denying service	An unencrypted USB drive is stolen	?
Software	Programs are deleted, denying access to users	An unauthorized copy of software is made	A working program is modified to cause it to fail or to cause it to do some unintended task
Data	Files are deleted, denying access to users	An unauthorized read of data is performed. An analysis of statistical data reveals underlying data	Existing files are modified or new files are fabricated
Communication Lines	Messages are destroyed or deleted. Communication lines or networks are rendered unavailable	Messages are read. Traffic patterns are observed	Messages are modified, delayed, reordered, duplicated. False messages are fabricated

Scope of Computer Security

Reads the content of the card (that isn't properly secured)

Example: the [ATM skimmers]

	Integrity
	?
	A working program is modified to cause it to fail or to cause it to do some unintended task
	Existing files are modified or new files are fabricated
Co	Messages are modified, delayed, reordered, duplicated. False messages are fabricated

Scope of Computer Security

ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

	Availability	Confidentiality	Integrity
Hardware	Equipment is stolen or disabled, thus denying service	An unencrypted USB drive is stolen	
Software	Programs are delet… denying access to u…		…rking program is … to cause it to fail or …use it to do some …intended task
Data	Files are deleted, denying access to users	An unauthorized read of data is performed. An analysis of statistical data reveals underlying data	Existing files are modified or new files are fabricated
Communication Lines	Messages are destroyed or deleted. Communication lines or networks are rendered unavailable	Messages are read. Traffic patterns are observed	Messages are modified, delayed, reordered, duplicated. False messages are fabricated

Or **encrypted!**

Sco

	rity
Hardwar	
Software	rogram is use it to fail or o do some ed task
Data	e modified or fabricated
Communicatio	e modified, eordered, lse messages icated

Sco

	...rity
Hardwar...	
Software	...program is ...use it to fail or ...o do some ...ed task
Data	...e modified or fabricated
Communicatio...	...e modified, ...eordered, ...lse messages ...icated

Based on Zero-Days (discovered but not reported to Microsoft, so stolen by other company)

Case Study: WannaCry

Scope of Computer Security

ALMA MATER STUDIORUM UNIVERSITÀ DI BOLOGNA

	Availability	Confidentiality	Integrity
Hardware	Equipment is stolen or disabled, thus denying service	An unencrypted USB drive is stolen	
Software	Programs are deleted, denying access to users	An unauthorized copy of software is made	A working program is modified to cause it to fail or to cause it to do some unintended task
Data	Files are deleted, denying access to users	An unauthorized read of data is performed. An analysis of statistical data reveals underlying data	Existing files are modified or new files are fabricated
Communication Lines	Messages are destroyed or deleted. Communication lines or networks are rendered unavailable	Messages are read. Traffic patterns are observed	Messages are modified, delayed, reordered, duplicated. False messages are fabricated

Passive and Active Attacks

- **Passive attacks** attempt to **learn** or make use of information from the system **but do not affect** (no modification to) **system resources** (Example: sniff packets during communication)
  - Eavesdropping is the unauthorized interception of private communication: this usually means capturing "packets" of data as they travel from Point A to Point B. (to avoid that they get sensitive information, use encryption)
  - **example**: **eavesdropping**/**monitoring** of transmissions
  - **difficult to detect** because you have small or no evidence that they are doing Passive Attacks (because there aren't any type of modifications to system resources)
  - emphasis is on **prevention rather than detection**
  - **two main types** of passive attacks (**message contents**, **traffic analysis**)

- Disclosure of Message Contents: The attacker intercepts the communication and reads the plaintext, that is not encrypted.
- Traffic Analysis: Even if the messages are encrypted, the attacker observes the data flow. They see who is talking to whom, the frequency of messages, their size, and connection times. Example in your system: The attacker notices that a user's IP address suddenly sends a burst of encrypted packets to the company server at exactly every hour. Even if they don't know what's written, they suspect it's an automatic backup or a critical data exchange.

Passive and Activ

The transmission is intercepted

- **Passive attacks** attemp e
  system **but do not affect system** **rces**
  - **example**: **eavesdropping/monitoring** of transmissions
  - **difficult to detect**
  - emphasis is on **prevention rather than detection**
  - **two** main types (**message contents**, **traffic analysis**)

Passive and Active Attacks

- **Passive attacks** attempt to **learn** or make use of information from the system **but do not affect system resources**
  - **example**: **eavesdropping/monitoring** of transmissions
  - **difficult to detect**
  - emphasis is on **prevention rather than detection**
  - **two** main types (**message contents**, **traffic analysis**)

Passive and Active Attacks

Content can be in clear or encrypted (it depends on the channel encryption)

- **Passive attacks** attempt to
  system **but do not affect sy**
  - **example**: **eavesdroppi**
  - **difficult to detect**
  - emphasis is on **prevention rath** **an detection**
  - **two** main types (**message contents**, **traffic analysis**)

This happens when the message is transmitted "in clear" (not encrypted)

message text
encrypted: cypher text

When a message or data stream is encrypted

Even when the messages are encrypted it is possible to perform some analysis

For example: content size, frequency...

use of information from the

of transmissions

- **difficult to detect**
- emphasis is on **prevention rather than detection**
- **two** main types (**message contents**, **traffic analysis**)

It is important to be able to understand the different types of attack, so when you try to analyse the security of the system, it will be easier for you to try to follow these approach (an example is the table seen) and to ask to yourself if the system is prone to these types of attack

Passive and Active Attacks

attempt to alter system resources or affect their operation

- **Active attacks** involve **modification** of the data stream (or the attacked system)

If there is modification/interaction with the system, it is an active attack
If there isn't, it is a passive attack

  - the **goal** is to **detect** them and to **recover**
  - four main types: of active attacks
    - **masquerade**
    - **replay**
    - **modification of messages**
    - **denial of service**

Typically, these attacks occurs on the Internet because it is easier when there is a network than inside a system (more secure than internet and much harder)

- IDS (Intrusion Detection System): This is a monitoring software whose primary purpose is to identify anomalous, suspicious, or known malicious activity within a system or network. The IDS operates in passive mode: once an anomaly is detected, it generates an alert for system administrators, allowing them to verify whether it is legitimate behavior (a false positive) or to initiate recovery procedures.
- IPS (Intrusion Prevention System): This represents the active and reactive evolution of the IDS. The IPS does not simply detect the attack, but intervenes in real time to block it before it can compromise the system (for example, by terminating the malicious network connection or blocking the sender's IP address).

Typical Attack in the real world:
- Passive to gather information without being spotted
- Active to perform it using info gathered before

Passive ...

One entity pretends to be a different entity

Example: *a* ***user*** *or a* ***device***

- **Active at**... ...or the attacked...
  - the **goal** is to ... them and to **recover**
  - four main typ...:
    - **masquerade**
    - **replay**
    - **modification of messages**
    - **denial of service**

Passive and Ac

- **Active attacks** inv
  attacked system)
  - the **goal** is to
  - four main types
    - **masquerade**
    - **replay**
    - **modification of messages**
    - **denial of service**

In some type of attacks, you can use masquerade+replay (used to bypass both Authentication and Access Control.)

Direct Replay: no modifications
Attacker can modify the messagge if it isn't properly encrypted

Passive capture of a data unit and its subsequent retransmission to produce an unauthorized effect:

Man-In-The-Middle (MITM) attack

Example: "*Open sesame*"

Couple of words without meaning but i understand the semantic (opens the door)

"it is the subsequent retransmission" to define that it is an Active Attack

Passive and Active Attacks

- **Active at**   am (or the
  attacked
  - the g
  - four main ty
    - **masquer**
    - **replay**
    - **modification of messages** Modify a part of the communication
    - **denial of service**

I think that it is obvious

Example: *to change the IBAN code in a bank transfer*

Passive and Active Attacks

- **Active attac**
  attacked sy
  - the **goa**
  - four mai
    - **masquerade**
    - **replay**
    - **modificat** of messages
    - **denial of service**

An interruption in an authorized user's access to a computer network, typically one caused with malicious intent

Example: *the Mirai botnet*

is malware that turns networked devices running Linux into remotely controlled bots that can be used as part of a botnet in large-scale network attacks. It primarily targets online consumer devices such as IP cameras and home routers.

Even if they are important, It is very difficult to design a product that satisfies all design principles that are listed here. Not all the design principles have same importance: some of them are more important than others and it depends on your setup (a Bank has a Threat Model different from the others, for example)

Security Design Principles

IMPORTANT: this is a good guideline to how to design a proper cybersecurity aware system or evaluate a system

ALMA MATER STUDIORUM UNIVERSITÀ DI BOLOGNA

Another formulation of KISS principle

1 • **Economy of mechanism**: the design of security mechanisms ~~measures~~ should be **as simple** and small **as possible** (*i.e.* ***simpler*** *to implement and to verify*, ***fewer*** *vulnerabilities*)

2 • **Fail-safe default**: access decisions should be based on **permissions rather than exclusion** (*i.e., the* ***default*** situation *is lack of access*)

It is prefered to automatically restrict the permissions and, only by human intervention (admin), we will decide case by case who is authorized to enter in the system

Implementing Complete mediation is costly (in terms of design, interaction between the different parts, etc..)

3 • **Complete mediation**: every access should be checked against the **Access Control system** (*see Chapter 4*)

Authorization: what resources, the user authenticated, can access and with which permissions.

Permissions are tied to the OBJECT. The question is: What can be done to this file or folder? The control is "attached" to the resource. Example: The file bilancio.pdf has a list of instructions that says: "User Rossi can read it, user Bianchi can edit it." Privilege is tied to the SUBJECT. The question is: What superpowers does this user have in the operating system? The control is independent of the individual file. Example: The administrator has the "privilege to bypass file controls." If a file says "no one can read me," the administrator can still do so because their authority overrides the file's rule.

1. Permissions (Access to Objects) What it is: The authorization granted to an object (such as a file, database, or folder) determining what actions can be performed on it. Focus: "Can I read, write, execute, or delete this file?" Scope: It defines what you are allowed to do with a specific piece of data. Examples:" Read-only" access to a financial spreadsheet."Write/Modify" access to a shared team folder.
2. Privileges (System-Level Control) What it is: The authorization granted to an entity (like a user or system process) that allows them to perform high-level, administrative, or system-wide tasks. Focus: "Do I have the power to change system settings, install software, or modify other users' access?" Scope: It defines who you are in the system hierarchy. Examples:Ability to install new applications or drivers.Ability to create, delete, or reset passwords for other users.Administrative access to alter firewall rules.

Security Design Principles

4 • **Open design**: the design of a security mechanism should be **open rather than secret** (*e.g., encryption algorithms*) (Shannon Reformulation)

No single person or process should have complete control over critical actions.

5 • **Separation of privileges**: **multiple privileges** should be required to achieve access to a restricted resource (or to complete some tasks)

Strongly Linked with

6 • **Least privilege**: every user (or software process) should operate **using the ~~least~~ minimum set of privileges** ~~necessary~~ required to perform a task (e.g., the sysadmin must **not** surf the Web using the administrator user)

otherwise, a single compromission, in a single part of the system, is able to get a lot of credentials, to compromise other parts of the system, etc..

It is the opposite of usability (when i use the PC i want all the permissions to avoid slowing my operations)

Security Design Principles

ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

(example: reduce the amount of accounts with same password because with one data breach, you are compromised on all accounts). When different users or programs share a mechanism (like a password, a database, or a piece of memory), that mechanism becomes a Single Point of Failure. When designing a system, it is important to minimize the number of functions, communication channels, or resources shared among different users or programs. If two distinct entities rely on the exact same mechanism to function, that mechanism becomes a major vulnerability for the security of the entire system.

7 - **Least common mechanism**: a design should minimize the **functions shared** by different users/~~entities~~ (*e.g., **sharing state** among different software programs*)

According to the principle, different environments and processes should be strictly isolated and partitioned, minimizing the sharing of functions, hardware, or software components among multiple users. When systems share common mechanisms, a security breach in one component can easily spread, allowing a compromise to propagate across the entire infrastructure rather than remaining confined to a single software module.

8 - **Psychological acceptability**: the security mechanisms should not **interfere** unnecessarily ~~unduly~~ with the work of users (*i.e. **user's acceptance** of security mechanisms*)

When we try to push for an increase of Security level, everytime you should consider carefully what is the psychological reaction of the users: if the psycological reaction of the users is something that is against the acceptability of enforcing this specific mechanism, we are doing something wrong:
1) Why are they reacting like that?
2) Investigating if there is a better way for doing things (most of the times, there are but costly and not so easy for admin, so we prefer to push the problem to the user instead of solving the problem as system administrator)

Full separation is not possible, because i also need inter-operability between applications (i need to have exceptions)

Security Design Principles

ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

When you design a system, you shouldn't aim for Maximum Isolation. Instead, you should aim for Optimal Isolation. You identify the most critical resources and isolate those, while leaving non-critical paths more open to keep the system fast (too much Isolation lowers system performance). Not all kinds of isolation are the same: there are different type of isolation (for example, is better the physical isolation than logical, but the physical one is costier than logical one) and different type of software/hardware isolation

9 - **Isolation**:

A ○ **public access** systems should be isolated from critical resources to prevent disclosure or tampering (*i.e., no connection between public and critical information*)

Example: (Air Gapping) If a component is exposed to the public (such as a web server), it must not have a "direct connection" to critical resources (such as the payment database or system files).

B ○ **users** processes and **files** should be isolated from one another (except when desired) (example: same computer, different users registered in the PC, so we have logical isolation of files: users are separated)

C ○ the **security mechanism** should be isolated as much as possible, otherwise it will be possible for the attacker to compromise the security mechanism and after that to escalate on the whole system (get super privilage on the system) (*i.e., preventing access to those mechanisms*)

With Modularity and Isolation, we enter the debate about The Monolithic Kernel vs. The Microkernel:
In a monolithic system (like Linux, Windows, or macOS), almost all core services (drivers, file systems, and the Security Module) run in the same "privileged" memory space (Kernel Space): we have more performance but less Isolation and Modularity.
A Microkernel (like QNX or L4) takes the opposite approach. It only keeps the absolute "bare essentials" in the kernel. Everything else (drivers, file systems, security) runs as a separate, isolated Module.

Security Design Principles

ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Idea: hide the internal complexity and data structures of the system, exposing only a controlled and well-defined interface to the outside world. By ensuring that, every modification or interaction is mediated by a dedicated and isolated software component: encapsulation effectively resolves concurrency issues and enhances accountability through strict mediation. Without visibility into these internal mechanisms, malicious actors cannot easily identify vulnerabilities, preserving the system's confidentiality and integrity.

10 - **Encapsulation**: similar to **object-oriented programming concepts** (*i.e., hide internal structures*)

Direct and unmediated modifications to a shared system resource, such as a data structure or a network file system, by multiple concurrent nodes introduce severe security and integrity risks. Without a centralized, isolated entity in charge of managing the access to this shared resource, the system cannot enforce security policies, leading to race conditions and a failure to maintain data integrity.

Idea: if i create a system in which the security functions are meld together with the other functions of the system, i have a problem because they are not properly separated (if there is modularity, it is easier to protect the security stuff of the system)

11 - **Modularity**: (refers both to the) A development of security functions as separated and ~~**separate**~~, **protected modules** and B use of a **modular architecture** (*for the mechanism **design** and **implementation***)

It is not easy to do it (implementation is hard to do). For example, the OS gives us the security module that is incorpored inside the OS: this goes against Modularity, but this is the best way of doing it because although i need to estrapolate the security module from the OS and put it in a separate part of the kernel. If you prioritize Modularity, the system becomes slow and users will hate it (Psychological Acceptability). If you prioritize Integration, the system is fast but one "Kernel Exploit" (like the SMB bug in WannaCry) can bypass every security check at once.

It is a good idea to centralize the Security Module instead of Replicate them in each File System

1) A security function or service (The "What") specifies what the system must guarantee in order to counter a threat and protect the CIA triad. Examples: The Data Confidentiality service (ensuring that unauthorized users cannot read a file), the Data Integrity service (ensuring that no one modifies a message during transmission), or the Authentication service (verifying the identity of whoever is accessing the system).
2. A security mechanism (The "How") is the concrete technical tool, algorithm, or software component used to put that function into practice and realize it. It represents how the security objective is actually achieved. Examples: The AES encryption algorithm, a cryptographic hashing function (such as SHA-256), a digital signature, or a password/MFA (Multi-Factor Authentication) system.

The difference between bad and good security is on the properly understanding of the Thread Model and not applying Security design principle that are useless and costly in situation in which they aren't able to mitigate the problem itself. If you apply a high-cost security principle to a low-risk asset, you aren't being "more secure", you are being inefficient.

Security Design Principles

ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Layering can be really good if it is able to enhance your security when considering the proper Threat Model (if you aren't, layering is only a problem of usability). Example: (online banking) if you consider, in the Threat Model, the compromission of the browser/user device, all the layering is totally useless because the browser is the single piece of software that is in charge of getting all of your credentials and to transfer all these credentials to the backend

Idea: risk reduction by heterogeneity. Instead of having a single line of defense, is better to have multiple lines of defense where each layer is implemented in a different way

12

- **Layering** (**defense in depth**): use of **multiple**, **overlapping** protection approaches (*e.g., multiple firewalls based on different technologies and approaches*)

Each layer is implemented in a different way (different technologies, manifactures, etc..). Example: different type of Firewall or different type of Authentications

Related to Management and Technical

Related to Psychology

13

Minimo stupore

- **Least astonishment**: a program or interface should always ~~respond~~ behave in a way that ~~is~~ ~~**least likely to astonish a user**~~ it causes to the user as little surprise as possible (*e.g., an error window that belong to what running program?*)

If the user can be misleaded on a window request, the security consequences can be terrible. For example, a window that asks to confirm the password, how to know if it is a legitimate one or another application that is trying to impersonate?

Security Mechanism

It is fundamental to create procedures before being involved in an attack (a document, well written and structured, that must be followed when something against the security policy happens. Example: what to do if network is compromised?)

ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Every time you take a decision consider carefully your attack surface

- It is (or it should be) **designed to**:
  - Goal: Actively prevent the breach from happening (Before the attack).
    prevent attackers from violating security policy
  - Goal: To immediately detect if something is going wrong or if the security policy has been violated (During the attack).
    detect attackers' violation of security policy
  - Goal: To react quickly to minimize damage while the attack is still going on (During the attack).
    response to **mitigate** attack
  - Goal: Ensure business continuity. If an attack is successful, the system must be designed to recover on its own and continue providing service (After the attack).
    recover, continue to function **correctly** even if **attack succeeds**
- No single mechanism is able to support all services:
  - **Example**: *authentication, authorization, availability, confidentiality, integrity, non-repudiation*

Attack Surface

The attack surface is composed by

- The **reachable** and **exploitable vulnerabilities in a system**:

Examples

  - **services listening on the network**
  - **services** that are **not protected by a firewall**
  - **software** that **processes incoming data** (*i.e. e-mails, web pages, office documents, pdf, whatsapp messages...*)
  - an **employee** (or a **subcontractor**) with **access to sensitive information**

Attack Surface

- The **reachable** and **exploitable** **vulnerabilities in a system**:
  - services **listening on the network**
  - ...at are **not protected by a firewall**
  - ...**ata** (*i.e. e-mails, web pages,* ...*essages...*)
  - an **employee** (or a **subcontractor**) with **access to sensitive information**

every time i have a socket listening on the network

“Open ports”: running processes using network sockets

(piece of software with a socket open and so the ability to perform comunication)

A "firewall" is a software or hardware tool used to restrict the network access to a system

bilities in a system:

Firewall: network security hardware or software designed to filter traffic based on a set of predefined rules.
- Standard Inspection (Packet Filtering): Traditionally, a firewall performs superficial checks by analyzing only the header of each individual packet (for example, verifying the source/destination IP addresses and TCP/UDP ports). It is crucial to remember that there is no guarantee of the header's integrity, as the information within it can be easily forged by an attacker.
- Deep Packet Inspection (DPI) and the Limits of Encryption: Modern firewalls are capable of performing deep inspection, analyzing not only the header but also the packet's payload in search of malware or anomalies. However, this in-depth analysis becomes impossible in the presence of encryption, since the payload's content is completely unreadable and inaccessible to the firewall itself.

- **services listening on** the ...rk
- **services** that are **not protected by a firewall**
- **software** that **processes incoming data** (*i.e. e-mails, web pages, office documents, pdf, whatsapp messages...*)
- an **employee** (or a **subcontractor**) with **access to sensitive information**

Its goal is to ~~permit~~ allow/grant authorized access and to deny unauthorized (i.e., malicious) attempts

bilities in a system:

- services listening on ... ork
- services that are **not protected by a firewall**
- **software** that **processes incoming data** (*i.e. e-mails, web pages, office documents, pdf, whatsapp messages...*)
- an **employee** (or a **subcontractor**) with **access to sensitive information**

Attack Surface

- The **reachable** and **exploitable** **vulnerabilities in a system**:
  - **services** **listening on the network**
  - **services** that are **not protected by a firewall**
  - **software** that **processes incoming data** (*i.e. e-mails, web pages, office documents, pdf, whatsapp messages...*)
  - an **employee** (or a **subcontractor**) with **access to sensitive information**

Attack Surface

... but also Application Programming Interfaces (APIs), SQL queries, web forms etc.. ...

bilities in a system:

- services that are ... ed by a firewall
- **software** that **processes incoming data** *(i.e. e-mails, web pages, office documents, pdf, whatsapp messages...)*
- an **employee** (or a **subcontractor**) with **access to sensitive information**

ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Network Scanning

NMAP

Exposed attack surface

What is it?

Check it out!

T1

Attack Surface: categories

Is difficult to assess if a software is local or not (is local when it doesn't send data on the internet): example, update checkers

ALMA MATER STUDIORUM UNIVERSITÀ DI BOLOGNA

The Attack Surface can be categorized in

- Three main **categories**
  1. ○ **network** attack surface (i.e. refers to **network vulnerability**)
  2. ○ **software** attack surface (i.e. refers to **software vulnerability**)
  3. ○ **human** attack surface (i.e. refers to vulnerabilities like **social engineering**, human error, and trusted insiders)
- **Attack surface analysis**
  - ○ it a security technique for evaluating **assessing the scale** portata (scala) **and severity of threats** to a system (i.e. *to decide* ***how to allocate*** *the available resources*)... it is **not easy**...

Attack surface analysis is fundamentally a risk management exercise (not a pure technical one). Identifying the most vulnerable points in a system is essential for the strategic allocation of security resources. However, accurately identifying these high-risk areas remains extremely complex.

Qualitative Approach

Attack Trees

There are a lot of approaches that can be used to do attack surface analysis, but it is more important to understand what are the concepts that are baseline of these approaches

The hard part of this approach is to list ALL the potential vulnerabilities and their paths to be followed by the attacker

ALMA MATER STUDIORUM UNIVERSITÀ DI BOLOGNA

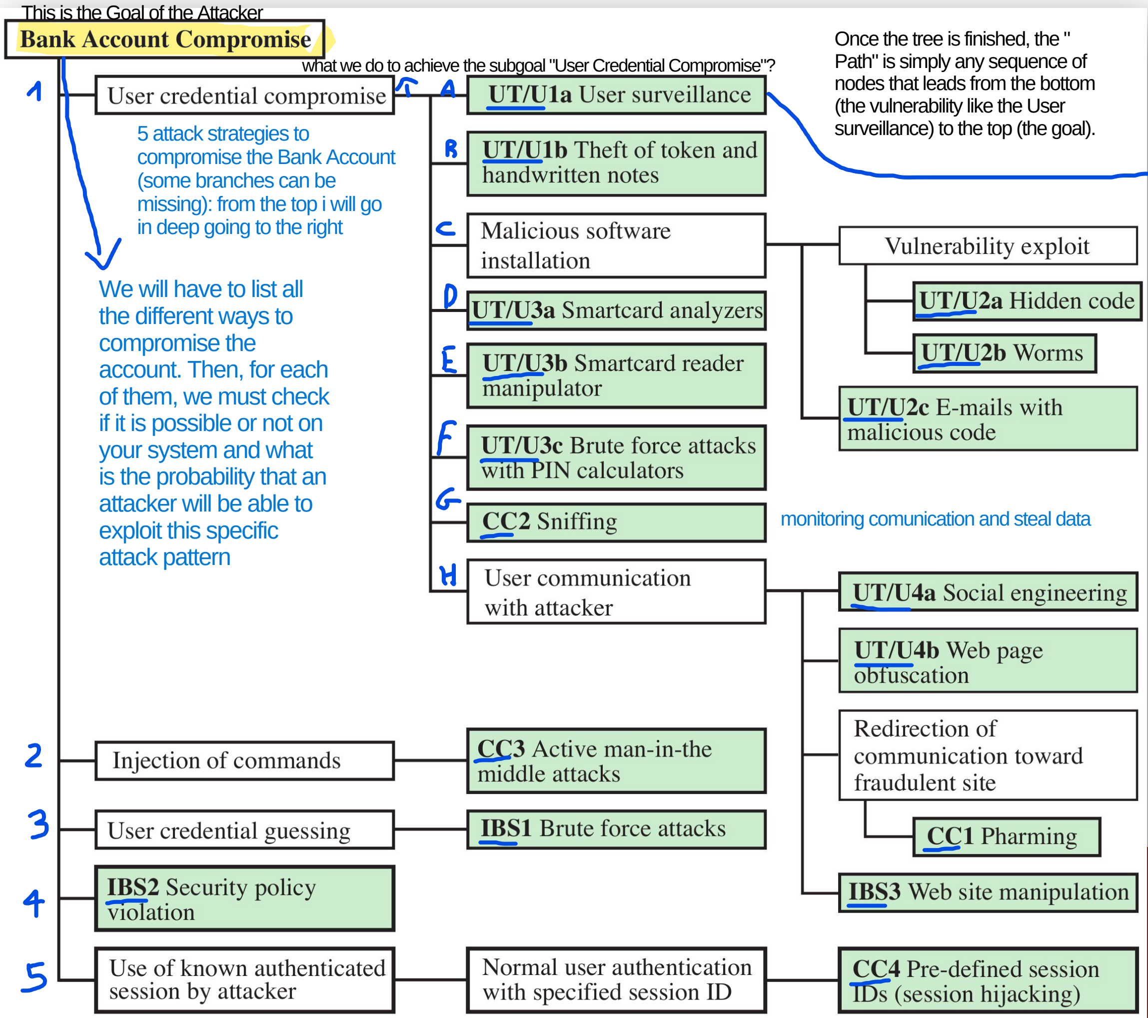
We use a plenty of Attack trees to analyse a system

- **Attack trees** are often used to perform **attack surface analysis**
- An **attack tree** is a **branching**, **hierarchical** data structure that **represents a set of potential** techniques for exploiting security **vulnerabilities**

The motivation for the use of attack trees is

- **Objective**: to effectively use in our favour the ~~exploit the~~ info available on **attack patterns** (*i.e. the methods* the attackers *used to find errors or problems in the systems*)
- **Attack trees** can be used by the **security analysts** **to guide design and strengthen countermeasures**

By annotating an attack tree with metrics such as the probability of a path being followed, we can conduct a comprehensive qualitative or quantitative risk assessment. This approach transforms the tree into a visual landscape of system risk, highlighting the paths an adversary is most likely to exploit. Consequently, security investments can be strategically directed toward reinforcing the highest-probability branches, ensuring an efficient allocation of resources to maximize overall risk reduction.



Once the tree is finished, the " Path" is simply any sequence of nodes that leads from the bottom (the vulnerability like the User surveillance) to the top (the goal).

Assign Attributes to the Paths

To make the tree useful for "allocating resources," you assign values to each leaf:

- Cost: How much money does the attacker need?
- Skill Level: Is this a "Script Kiddie" attack or a "Nation-State" level attack?
- Probability: How likely is this specific vulnerability to be found?

involves monitoring, recording, or intercepting a user's digital activities (such as keystrokes, camera feeds, or network traffic) to steal data or monitor behavior (from remote on the computer)

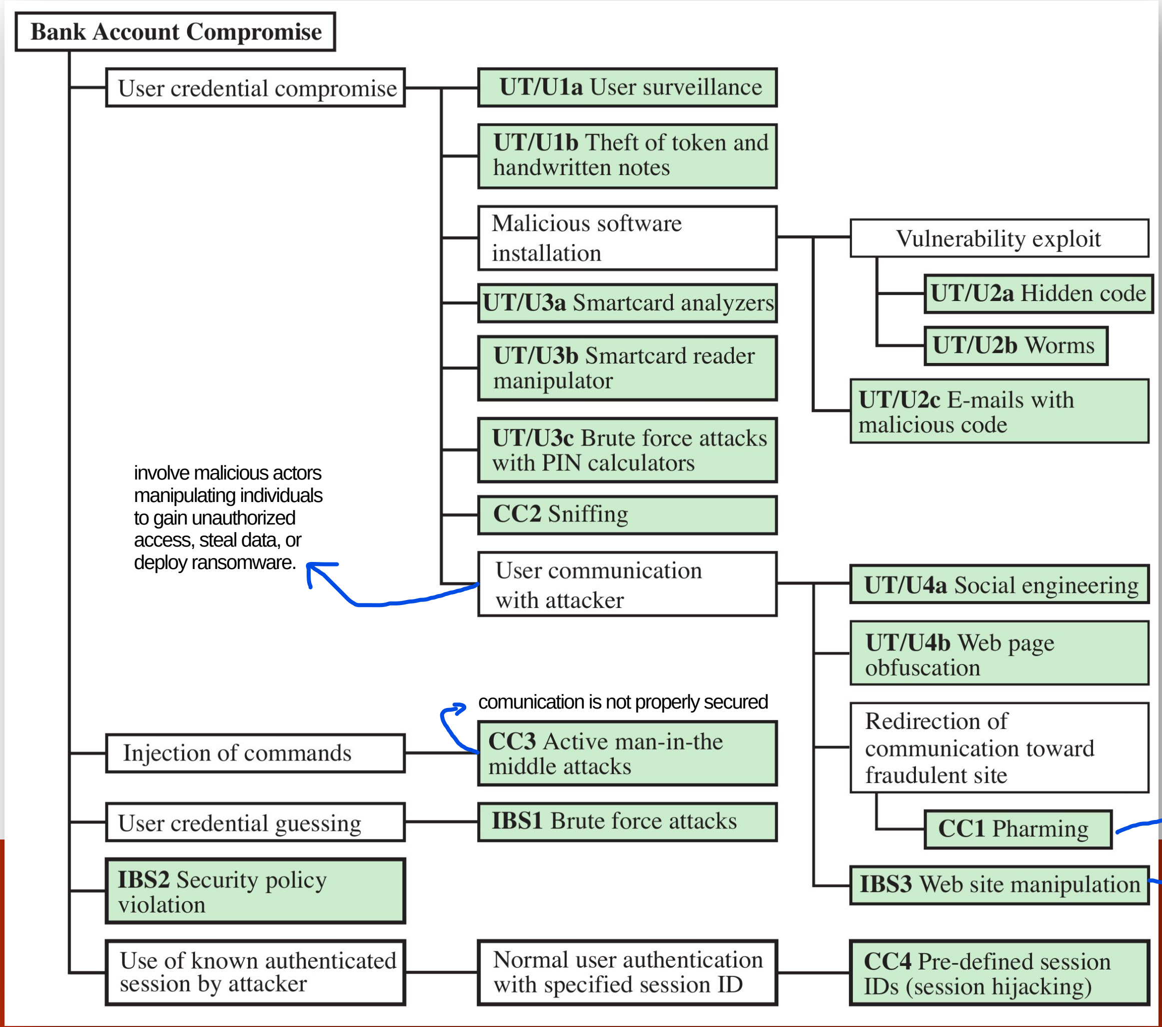
- Guessing is a trial-and-error approach. The attacker does not exploit a " hole" in the code; instead, they exploit the predictability of the secret or the weakness of the user's choice. It isn't a bug in the software; it's the low entropy (simplicity) of the password. (Example: Brute-force)
- Compromise (often referred to as Exploiting) is a technical circumvention. The attacker finds a way to "break" the logic of the system to get inside without ever needing to know the password or secret.

Sometimes, "Compromise" is used as a general term to say a system is no longer secure (e.g., "The server is compromised"). However, when comparing it to "Guessing," it specifically refers to exploiting a technical vulnerability rather than just hitting the right password by luck or persistence.

An Attack Tree is used in cybersecurity to visualize and analyse the different paths an attacker could take to achieve a specific goal. The tree is organized hierarchically:

- Root Node (The Goal): This is the ultimate objective of the attacker (e.g., "Steal administrator credentials" or "Shut down the power grid").
- Nodes of Branches (The Methods): These represent the different actions/subgoals that lead to the goal.

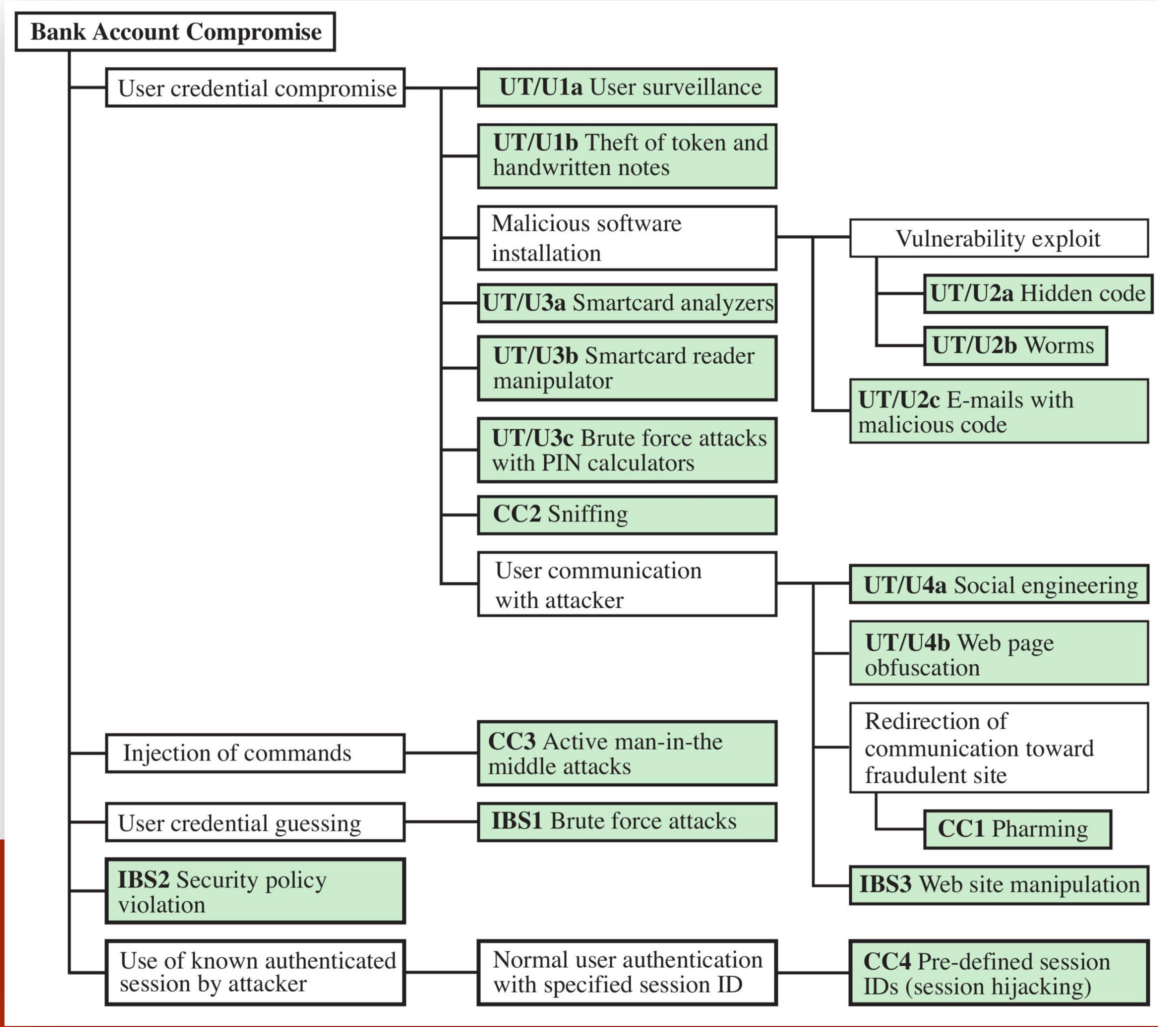
The goal is to compromise an online bank account



example: typosquatting, is a form of cybercrime where attackers register domain names similar to legitimate, popular websites, preying on user typos

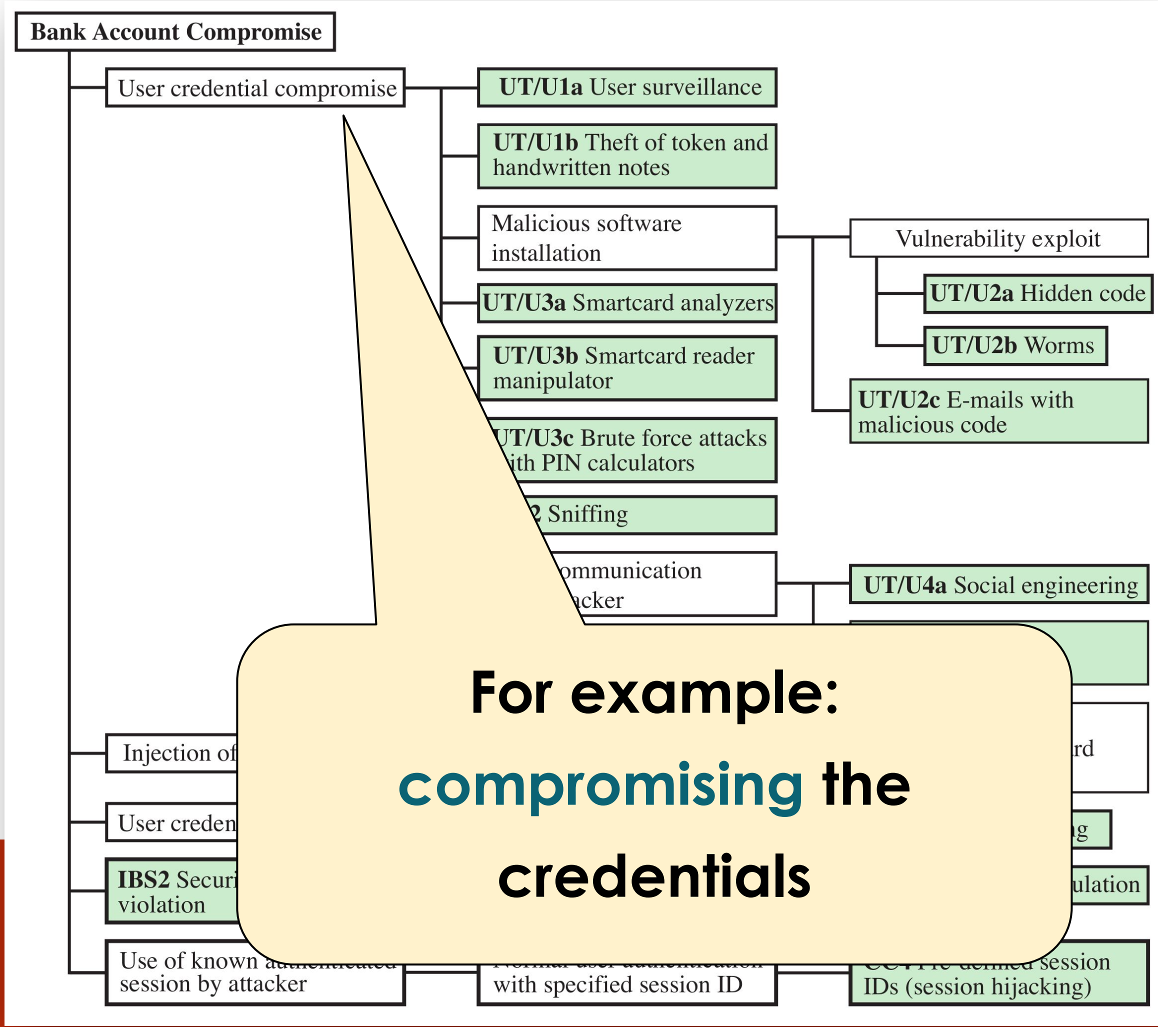
Pharming is a sophisticated cyberattack that redirects users from legitimate websites to fraudulent, attacker-controlled sites, even if the correct URL is typed. Unlike phishing, it often requires no user interaction after initial malware infection, making it highly deceptive. It steals sensitive data like banking credentials.

a part of the system can be poisoned



The goal is to compromise an online bank account

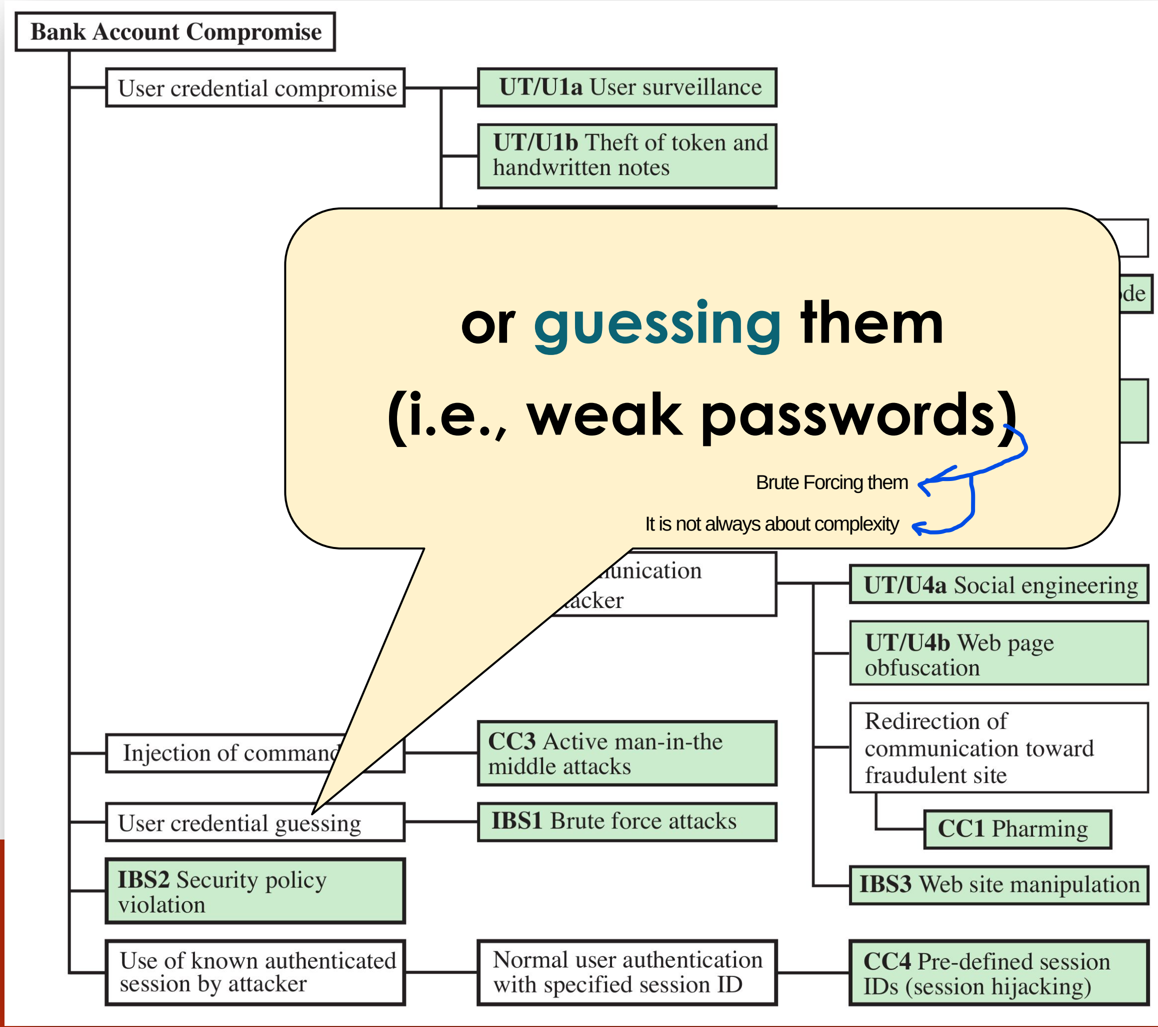
This can be done in many different ways



For example: **compromising** the credentials

The goal is to compromise an online bank account

This can be done in many different ways



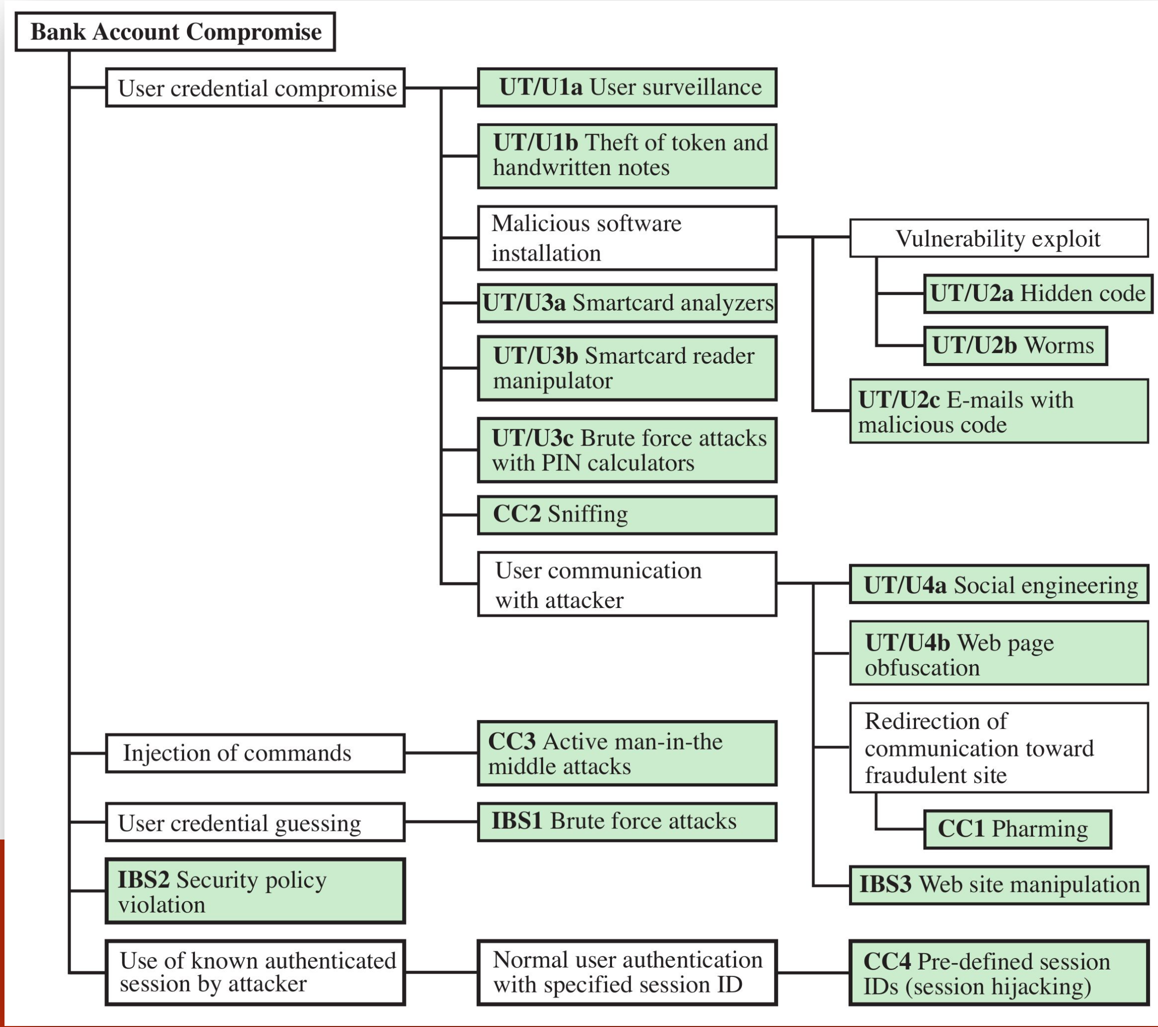
or guessing them (i.e., weak passwords)

Brute Forcing them

It is not always about complexity

The goal is to compromise an online bank account

This can be done in many different ways



Limitation of Attack Trees Approach
1) Being able to be qualitative or quantitative: to be quantitative you need data to assess the probability of each attack (without them, is a qualitative approach and is less accurate) and to define which are the most probabilistic attacks

You cannot prevent Zero days (at most, minimum prevention) because we don't have data about them (by definition of 0-days). The focus is on preventing the all that is not a 0-day

ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

CyberSecurity

Gabriele D'Angelo

<g.dangelo@unibo.it>

https://www.unibo.it/sitoweb/g.dangelo/en

Attributions and Notes

ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- Most of the slides are from: "**Computer Security: Principles and Practice**", 4th global edition, W. Stallings and Lawrie Brown
- Some others are from: Dr. **Mehmet H. Gunes** (Department of Computer Science & Engineering - University of Nevada, Reno)
- Some others are from: **Mario Cagalj**, Ph.D. (Faculty of Electrical Engineering, Mechanical Engineering and Naval Architecture (FESB), University of Split)
- Some others are from: Prof. **Hossein Saiedian**, University of Kansas
- The "risk matrix" is from this **blog**
- I wish to **thank all of them**, **any errors that remain are my sole responsibility**